



Microsoft Entra Security Workshop

Thomas Naunheim
Cyber Security Architect,
glueckkanja AG

Labs





Thomas Naunheim

Cyber Security Architect @glueckkanja AG
Microsoft MVP (Identity & Access, Cloud Security)

Live in Koblenz/Lahnstein, Germany



cloud-architekt.net



Naunheim.cloud



thomasnaunheim



Thomas_Live



Agenda

1. **Tenant Hardening:**
Überwachung und Bewertung von "Default" Einstellungen
 2. **Conditional Access:**
Schwachstellen und Best Practices für Policy Design
-
3. **Privilegierter Zugriff:**
Administrative Konten und Delegationen
 4. **Non-Human Identities:**
Inventarisierung, Verwaltung und Absicherung



Tenant Hardening: Überwachung und Bewertung von "Default" Einstellungen

Tenant Einstellungen im Portal

The screenshot displays the Microsoft Entra ID portal interface. The breadcrumb navigation at the top reads: **Dashboard > Security | Authentication methods >**. Below this, a secondary breadcrumb path is visible: **Dashboard > CloudLab | Enterprise applications > Enterprise applications | User settings >**. The main heading is **Consent and permissions | User consent settings**. The left-hand navigation pane shows a tree structure with 'Groups' selected under 'CloudLab | Groups > Groups'. The main content area is titled **CloudLab | User settings** and includes a 'Microsoft Entra ID' header with 'Refresh' and 'Got feedback?' links. The settings are organized into two sections: 'Default user role permissions' and 'Guest user access'. The 'Default user role permissions' section contains three toggle switches, all set to 'Yes': 'Users can register applications', 'Restrict non-admin users from creating tenants', and 'Users can create security groups'. The 'Guest user access' section features a 'Learn more' link and three radio button options for 'Guest user access restrictions'. The third option, 'Guest user access is restricted to properties and memberships of their own directory objects (most restrictive)', is selected. At the bottom of the settings area, there is a section for 'Users can create Microsoft 365 groups in Azure portals, API or PowerShell' with 'YES' and 'NO' radio buttons.

Dashboard > Security | Authentication methods >

Dashboard > CloudLab | Enterprise applications > Enterprise applications | User settings >

Consent and permissions | User consent settings

Dashboard > CloudLab | Groups > Groups

Groups | General

Dashboard > CloudLab

CloudLab | User settings

Microsoft Entra ID

Refresh Got feedback?

Default user role permissions

[Learn more](#)

Users can register applications ☒ Yes

Restrict non-admin users from creating tenants ☒ Yes

Users can create security groups ☒ Yes

Guest user access

[Learn more](#)

Guest user access restrictions ☐ Guest users have the same access as members (most inclusive)

☐ Guest users have limited access to properties and memberships of directory objects

☒ Guest user access is restricted to properties and memberships of their own directory objects (most restrictive)

Users can create Microsoft 365 groups in Azure portals, API or PowerShell ☒ YES ☐ NO



Authorization Policy via Microsoft Graph API

```
GET "https://graph.microsoft.com/beta/authorizationPolicy"
```

```
"@odata.context":  
"https://graph.microsoft.com/beta/$metadata#policies/authorizationPolicy",  
  
"value": [  
  {  
    "displayName": "Authorization Policy",  
    "id": "authorizationPolicy",  
    "allowInvitesFrom": "adminsAndGuestInviters",  
    "allowedToSignUpEmailBasedSubscriptions": true,  
    "allowedToUseSSPR": true,  
    "defaultUserRolePermissions": {  
      "allowedToCreateApps": true,  
      "allowedToCreateSecurityGroups": true,  
      "allowedToCreateTenants": false,  
      "allowedToReadBitlockerKeysForOwnedDevice": true,  
      "allowedToReadOtherUsers": true  
    }  
  }  
]
```



Authorization Policy Check Definition in EIDSCA

```
"Name": "allowedToCreateApps",
"DisplayName": "Default User Role Permissions - Allowed to create Apps",
"CheckId": "EIDSCA.AP10",

"SkipCondition": "",
"SkipReason": "",

"CurrentValue": "defaultUserRolePermissions.allowedToCreateApps",
"DefaultValue": "true",
"RecommendedValue": "false",

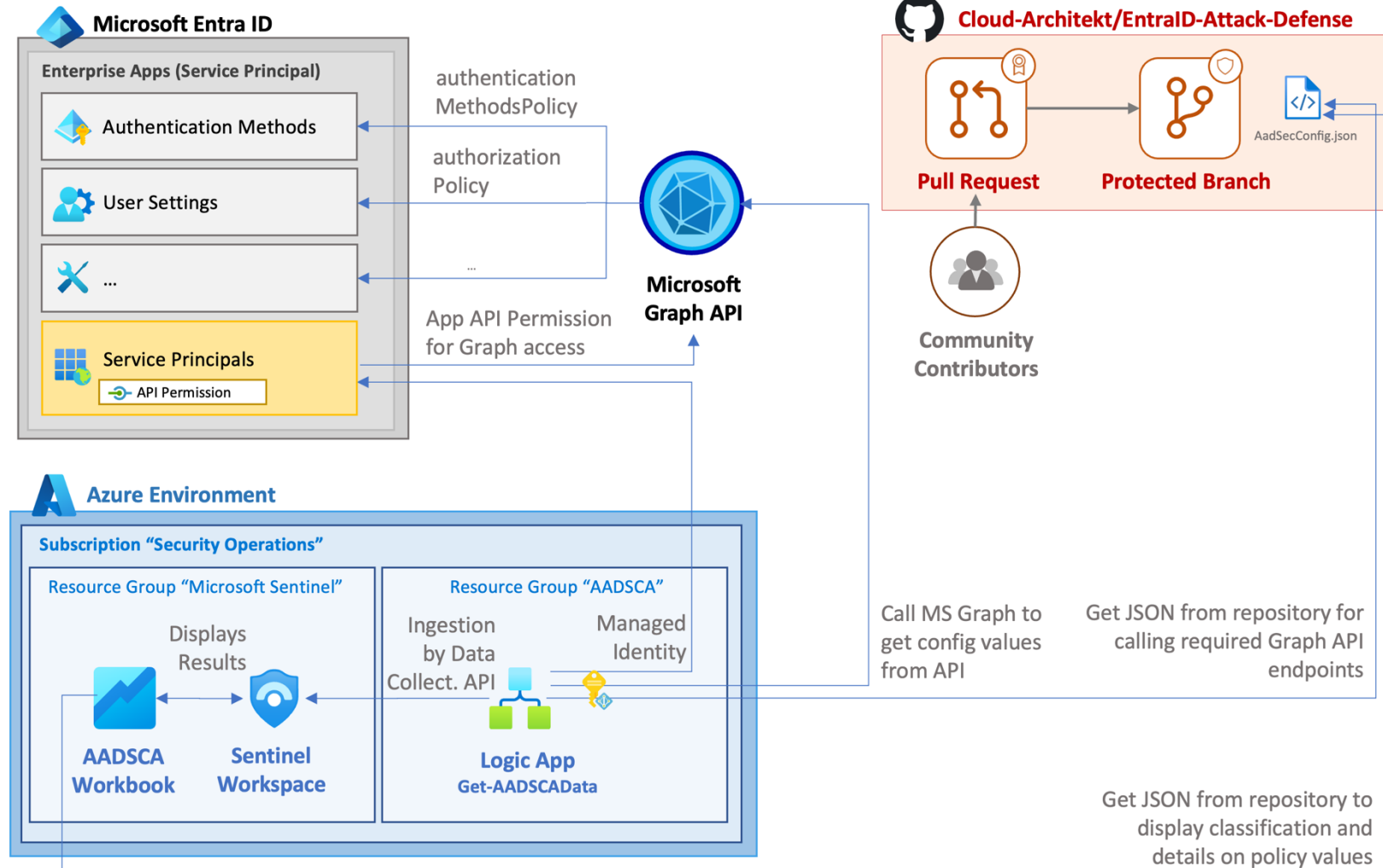
"Recommendation": "CISA SCuBA 2.6: Only Administrators SHALL Be Allowed To Register 3rd Apps",
"Severity": "High",

"MitreTactic": ["TA0001 - Initial Access", ...],
"MitreTechnique": ["T1566.002", ...],
"MitreMitigation": ["M1017", ...],

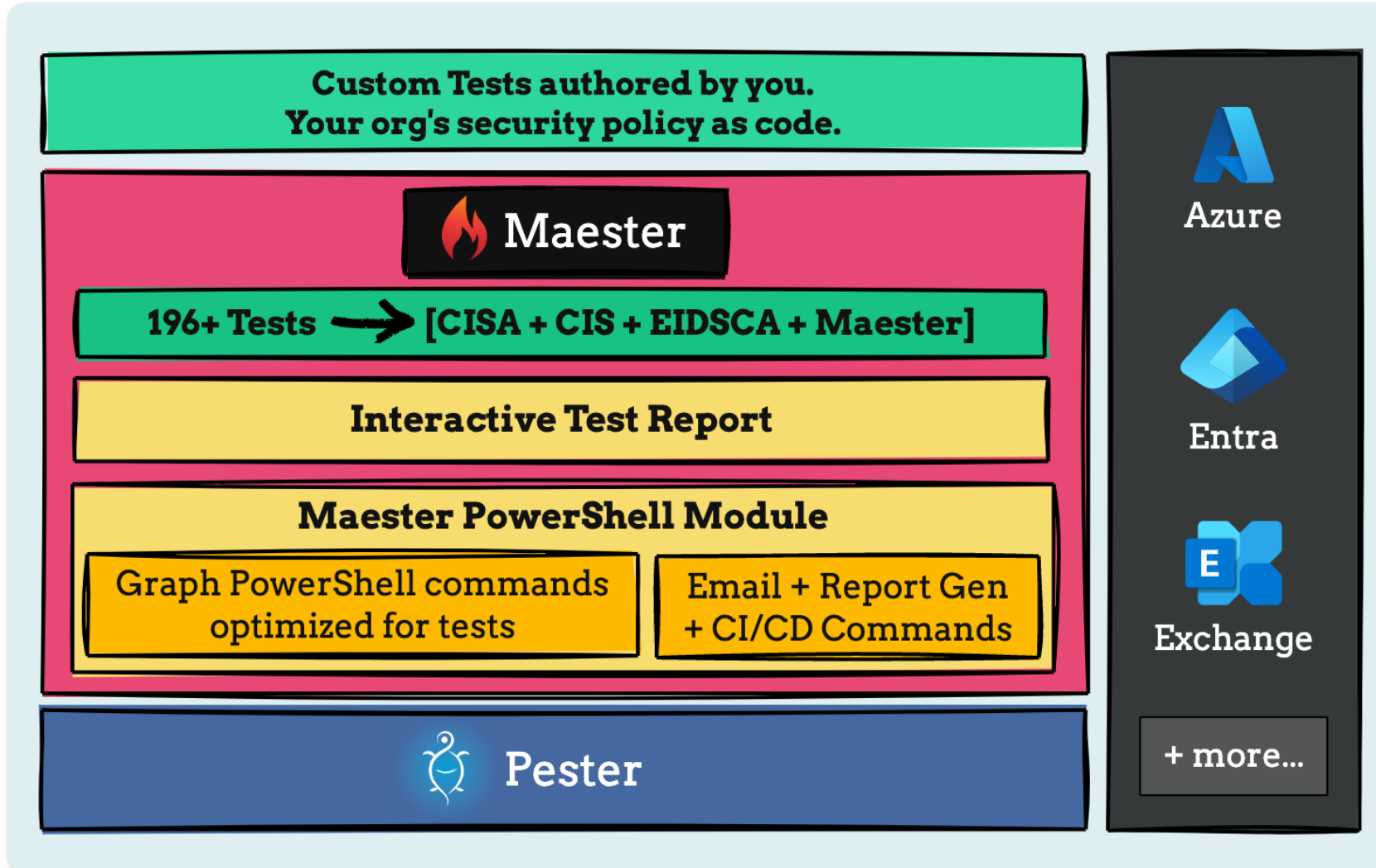
"PortalDeepLink": "https://entra.microsoft.com/.../UserManagementMenuBlade/~/UserSettings",
"Description": "Controls if non-admin users may register custom-developed applications (...)",
"HowToFix": "Microsoft Graph PowerShell: Update-MgPolicyAuthorizationPolicy (...)"
```

Monitoring der Tenant Konfiguration

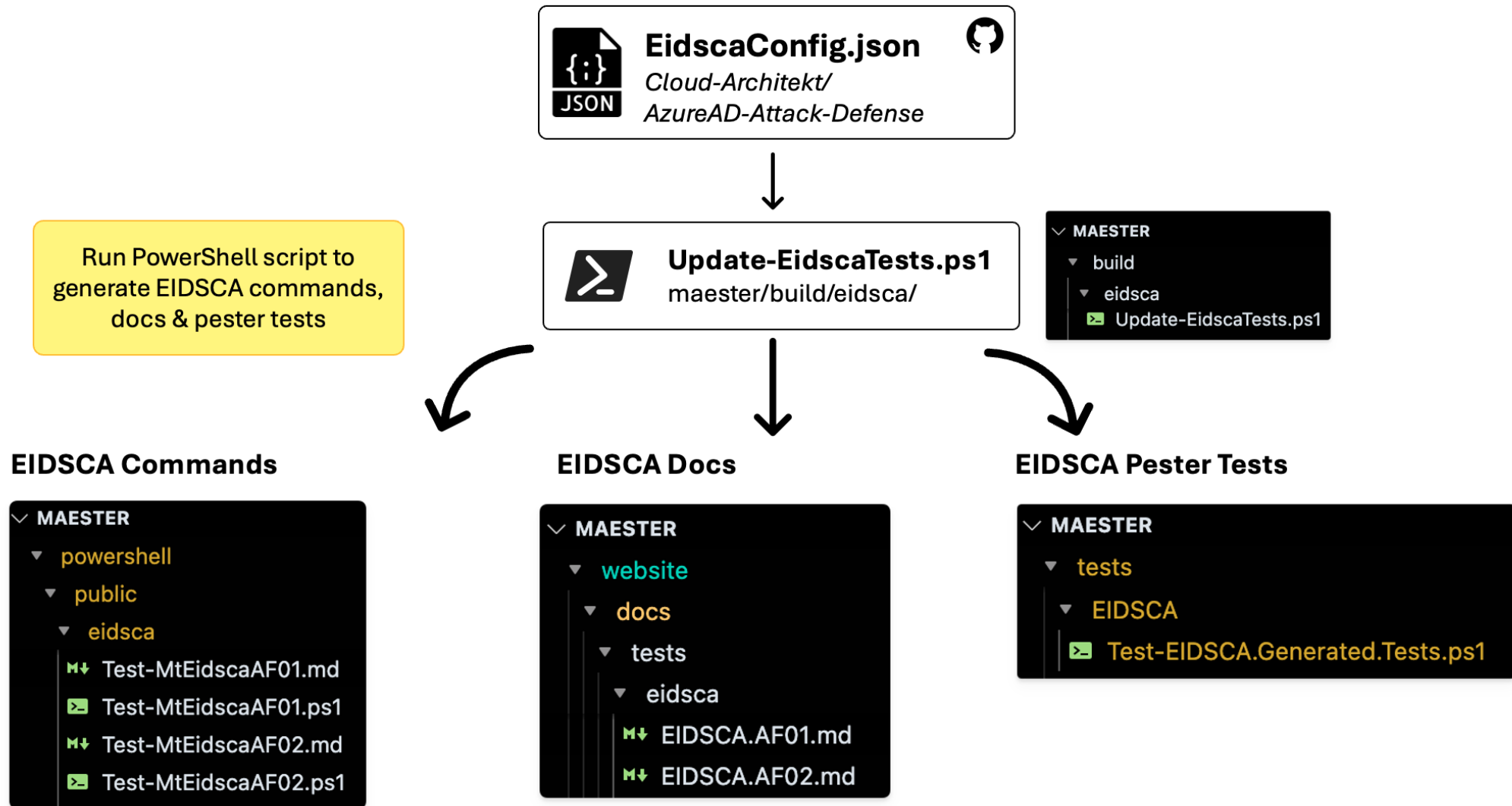
Entra ID Security Config Analyzer EIDSCA



Maester Framework



EIDSCA + Maester





Hands-On

Tenant Hardening:

1.1 Analyse der Microsoft
Entra Tenant Configuration
mit Maester



Baseline Security Mode

Adoption of strong secure-by-default settings & eliminating vulnerabilities caused by legacy configurations

Home

Copilot

Users

Teams & groups

Roles

Resources

Marketplace

Billing

Support

Settings

Domains

Search & intelligence

Org settings

Microsoft 365 Backup

Integrated apps

Viva

Partner relationships

Microsoft Edge

Setup

Reports

Health

Admin centers

Home > Org settings

Org settings

ServicesSecurity & privacyOrganization profile

Name ↑	Description
 Baseline security mode	Microsoft minimum security benchmark recommendations.
 Customer lockbox	Set requirements for data access.
 Help & support query collection	Choose whether Microsoft can use your organization's support queries to improve help & support.
 Idle session timeout	Automatically sign users out of the Microsoft 365 web apps after a period of inactivity.
 Microsoft Graph Data Connect applications	Approve and deny requests from apps to access your organization's Microsoft 365 data.
 Name pronunciation	Allow all users in your organization to set the pronunciation of their name across Microsoft 365.
 Password expiration policy	Set the password policy for all users in your organization.
 Privacy profile	Set the privacy statement of your organization.
 Privileged access	Set scoped access for privilege tasks and data access within your organization.
 Pronouns	Allow all users in your organization to set their pronouns across Microsoft 365.
 Self-service password reset	Let users reset their own forgotten passwords rather than contacting your organization's IT for help.

Baseline security mode

Reduce your attack surface and harden your organization from malicious attacks. We recommend that you apply all default policies immediately.

To apply policies individually, select Manage all policies.
[Learn more about baseline security mode](#)

☒ Automatically apply default policies

Microsoft will apply all default policies that are recommended because they usually have little impact for organizations.

View default policies (7)

☐ Generate reports and consent to view sensitive data for remaining policies

This will initiate the generation of impact reports for the remaining policies. Baseline security mode impact reports contain end-user identifiable information (EUII) and some require tenant-level audit logs for Word, Excel, PowerPoint and OneNote. If you want to view impact reports, you must consent to view this data.

View remaining policies (11)

Save

Manage all policies

Baseline security mode

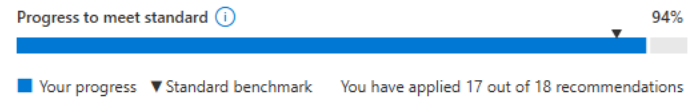
Manage these policies to reduce your attack surface and harden your Microsoft 365 organization from malicious attacks. Each policy is recommended to reach the minimum security benchmark.

[Learn about baseline security mode and why it's important](#)

Recommended setting automation

Microsoft recommended setting adjustments as of Tue Nov 11 2025

Report settings



Filters:

Category: all

Workload: all

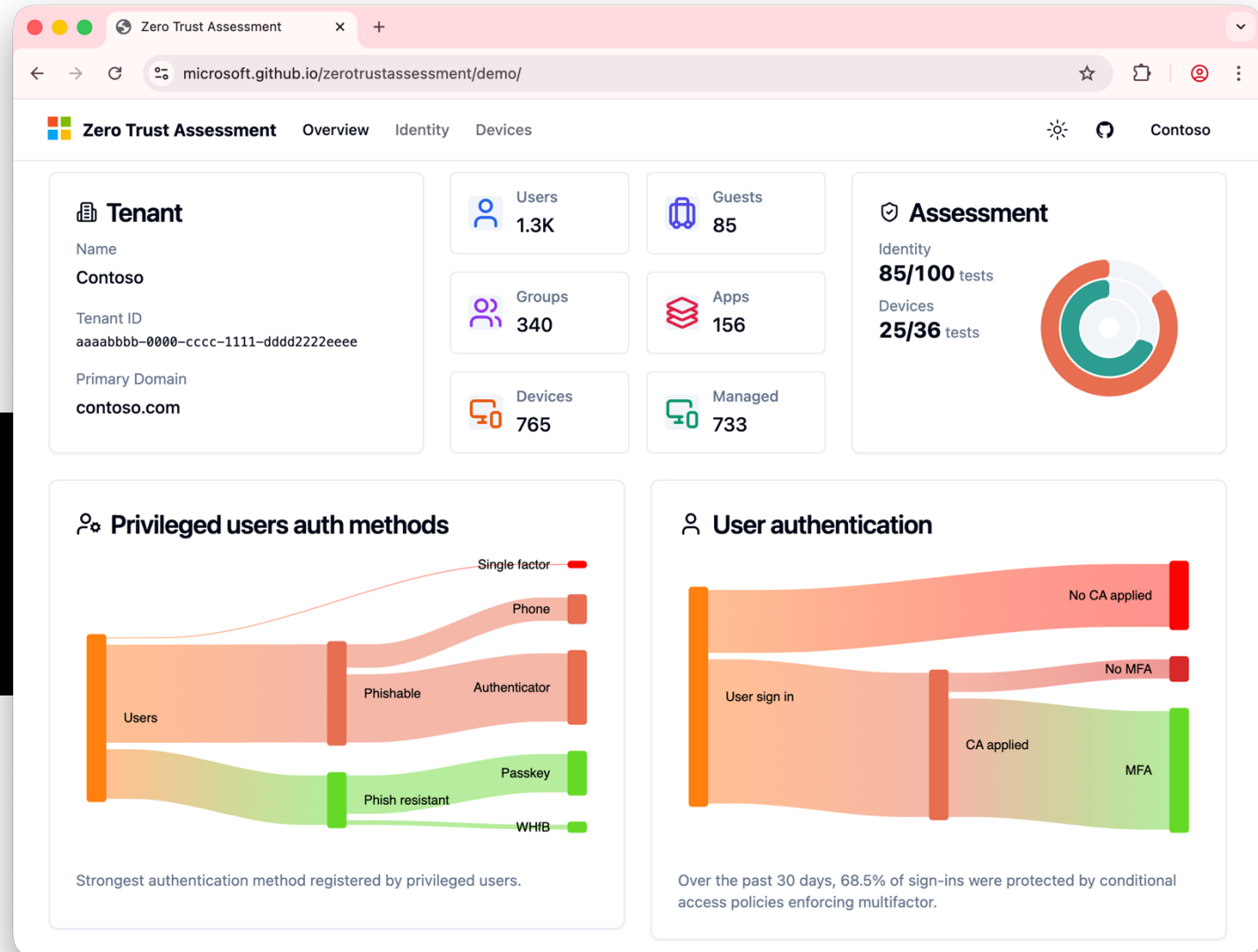
Status: all

Reset all filters

Setting recommendation	Status	Service
Authentication (12)		
Require phishing-resistant authentication for admins	In review	Entra ID
Block legacy authentication	Meets standard	Entra ID
Block new password credentials in apps	Meets standard	Entra ID
Turn on restricted management user consent settings	Meets standard	Entra ID
Block access to Exchange Web Services	Meets standard	Exchange
Block basic authentication prompts	Meets standard	Microsoft 365 apps
Block files from opening with insecure protocols	Meets standard	Microsoft 365 apps
Block files from opening with FPRPC protocol	Meets standard	Microsoft 365 apps
Block legacy browser authentication connections to SharePoint	Meets standard	SharePoint
Block IDCRL protocol connections to SharePoint	Meets standard	SharePoint

Zero Trust Assessment V2

```
Install-Module ZeroTrustAssessment  
Connect-ZtAssessment  
Invoke-ZtAssessment -Path C:\Report
```



Zero Trust Assessment V2

The screenshot displays the Zero Trust Assessment V2 interface. On the left, a sidebar lists various documentation topics under 'Fundamentals documentation' and 'Set up your tenant and directory'. The main content area shows a 'Test result' for the 'Inactive applications don't have highly privileged built-in roles' test, which has failed. Below the test result, a table lists 'Apps with privileged Entra built-in roles', showing one application: 'AppRolePimAutomationTestParentAcc19Feb22' with the role 'Administrator'. A 'What was checked' section explains that attackers might exploit valid but inactive applications with elevated privileges. A 'Remediation action' section lists steps: 'Disable inactive privileged service principals', 'Investigate if the application has legitimate use cases', and 'If service principal doesn't have legitimate use cases, delete it'. A red arrow points from the 'Inactive applications don't have highly privileged built-in roles' test result to the 'What was checked' section. Another red arrow points from the 'Inactive applications don't have highly privileged built-in roles' test result to the 'Apps with privileged Entra built-in roles' table.

Inactive applications don't have highly privileged built-in roles

Test result → **Failed**

Found 1 inactive applications with privileged Entra built-in roles

Apps with privileged Entra built-in roles

Name	Role	Assignment	App owner tenant	Last sign in
✗ AppRolePimAutomationTestParentAcc19Feb22	Application Administrator	Permanent		

What was checked

Attackers might exploit valid but inactive applications that still have elevated privileges. These applications can be used to gain initial access without raising alarm because they're legitimate applications. From there, attackers can use the application privileges to plan or execute other attacks. Attackers might also maintain access by manipulating the inactive application, such as by adding credentials. This persistence ensures that even if their primary access method is detected, they can regain access later.

Remediation action

- [Disable inactive privileged service principals](#)
- Investigate if the application has legitimate use cases. If so, [analyze if a OAuth2 permission is a better fit](#)
- [If service principal doesn't have legitimate use cases, delete it](#)

App registrations use safe redirect URIs

OAuth applications configured with URLs that include wildcards, or URL shorteners increase the attack surface for threat actors. Insecure redirect URIs (reply URLs) might allow adversaries to manipulate authentication requests, hijack authorization codes, and intercept tokens by directing users to attacker-controlled endpoints. Wildcard entries expand the risk by permitting unintended domains to process



Unified Tenant Configuration Management (UTCMM)



Configuration-as-Code platform for all Microsoft Clouds



Supports configurations for 7 of the major M365 Workloads



Works for organizations with 1 or 1,000+ tenants



Exchange Online



Entra Id



Intune



Purview



Defender



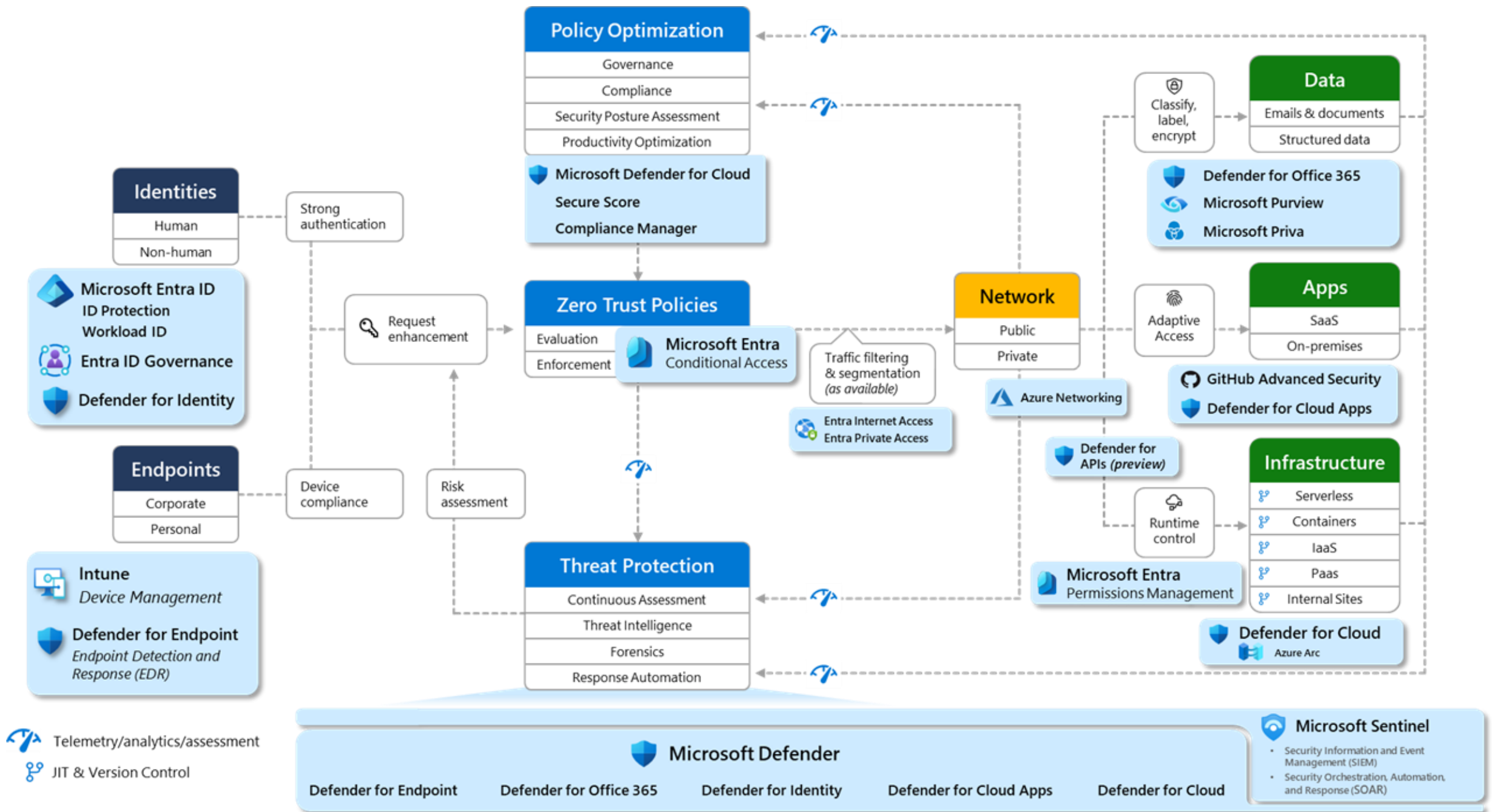
OneDrive/SharePoint



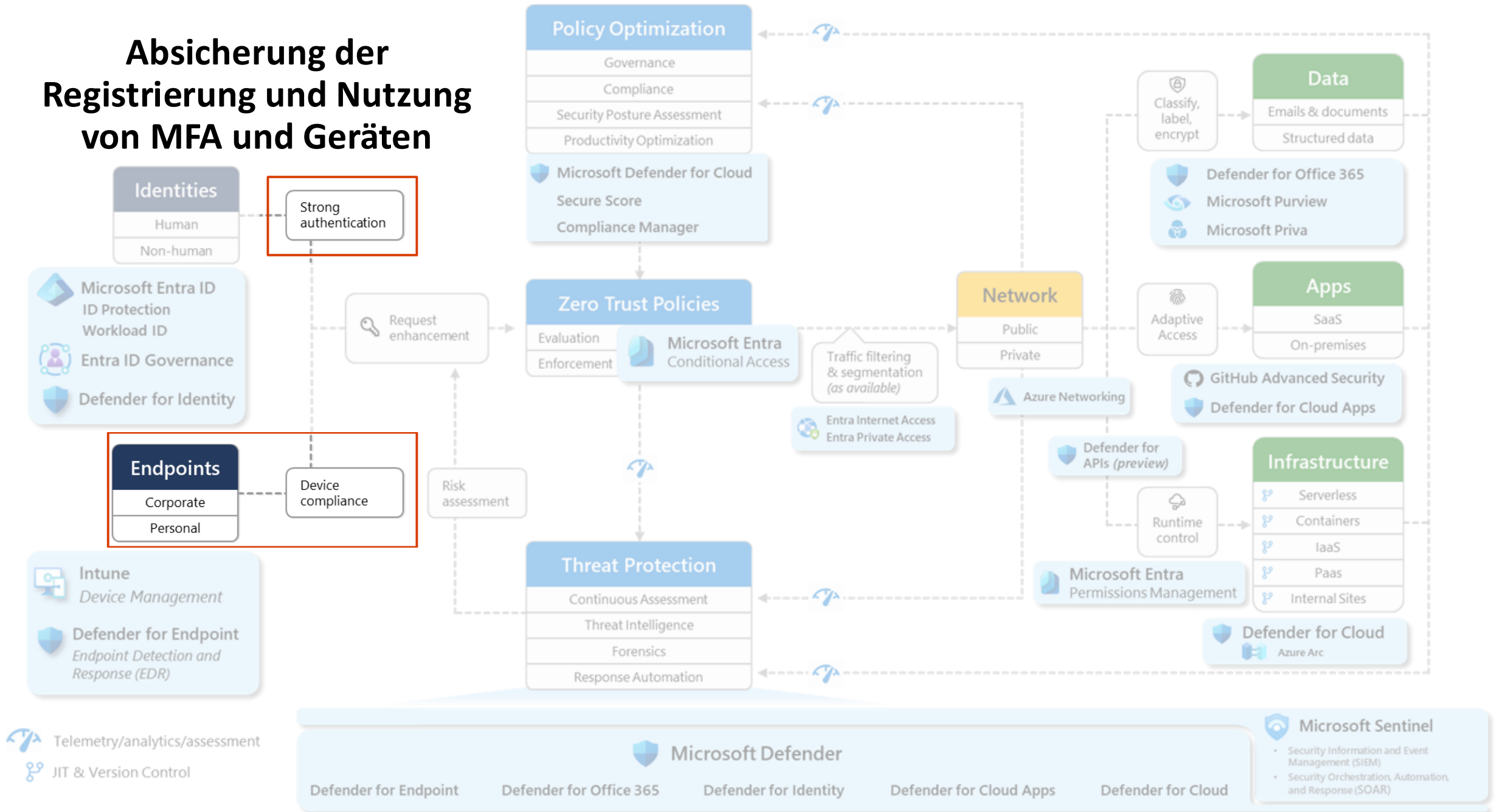
Teams



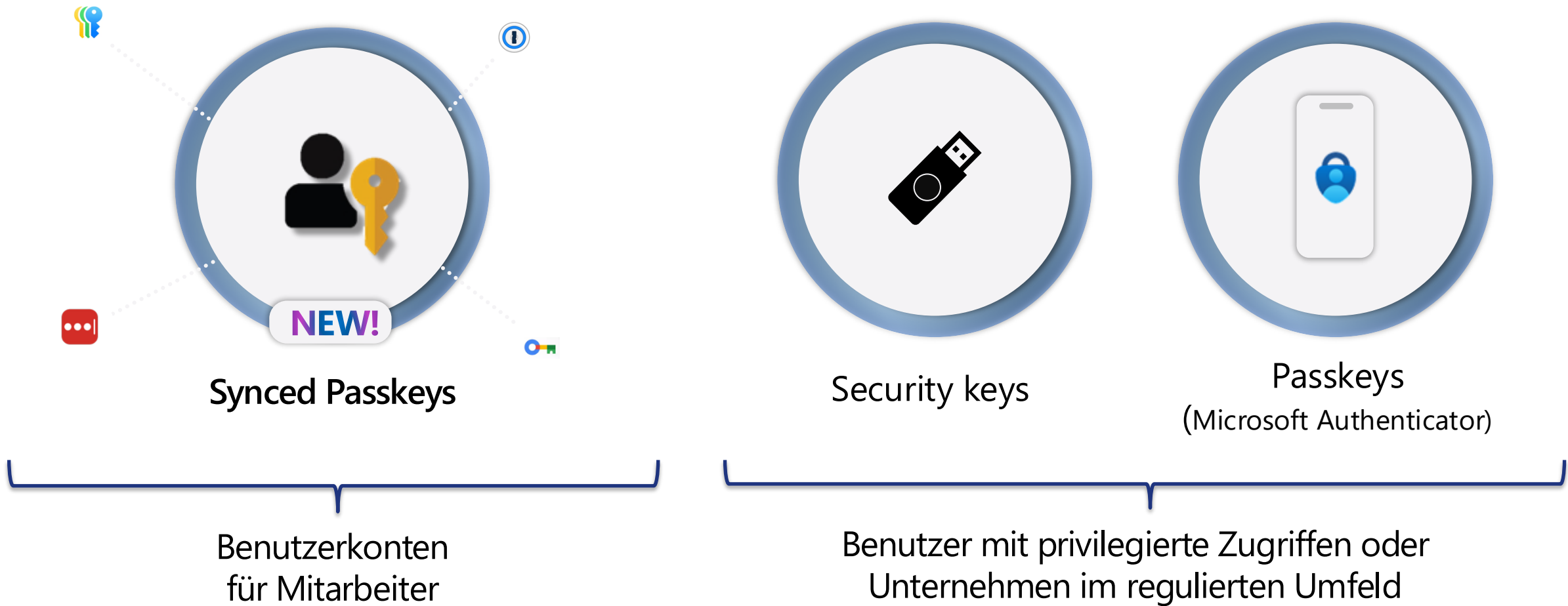
Conditional Access: Schwachstellen und Best Practices für Policy Design



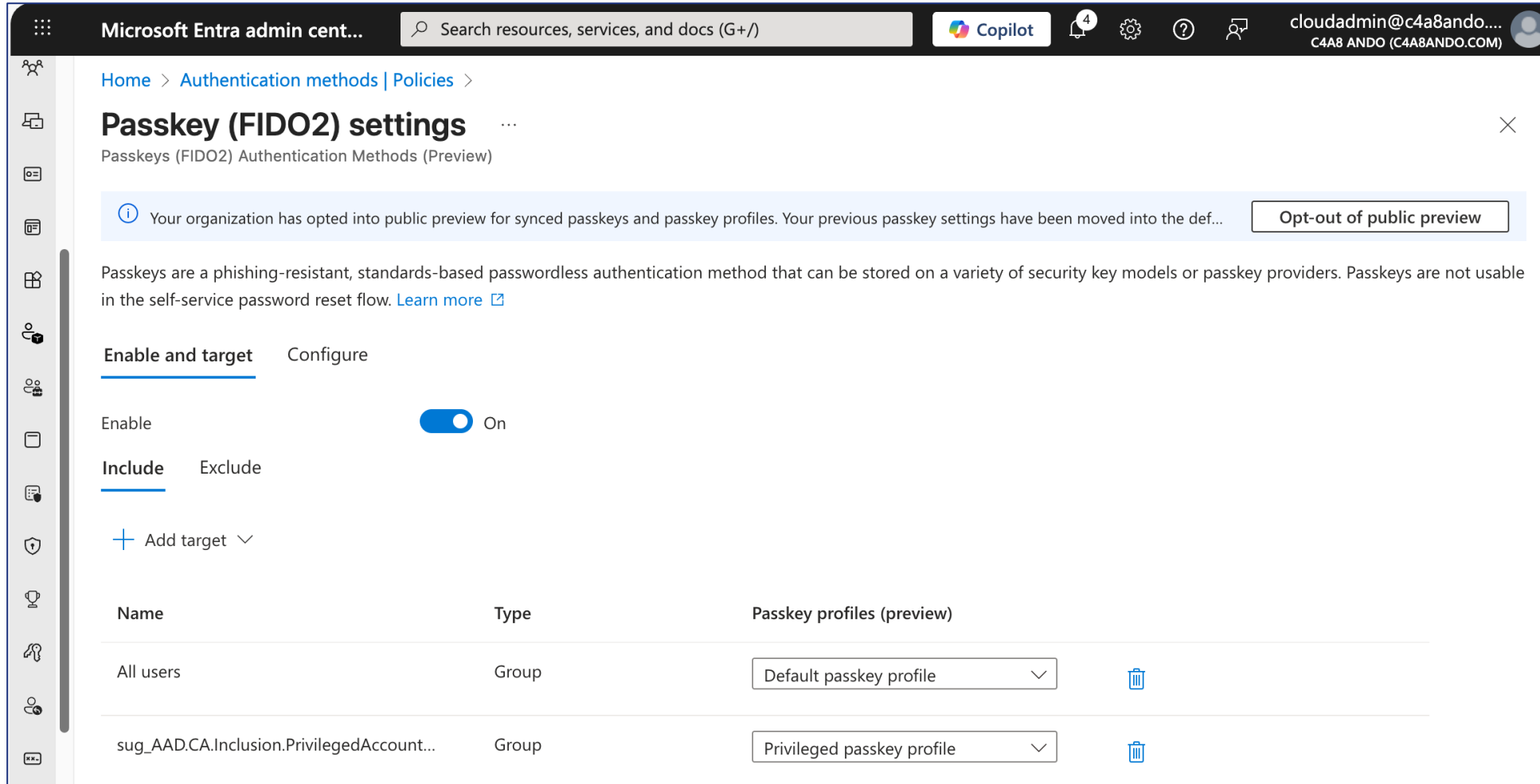
Absicherung der Registrierung und Nutzung von MFA und Geräten



Passwordless + Phishing Resistent



Granulare Konfiguration auf Gruppen (!= Tenant)



The screenshot displays the Microsoft Entra admin center interface. The top navigation bar includes the Microsoft Entra admin center logo, a search bar, and various utility icons like Copilot, notifications, settings, help, and a user profile. The main content area is titled 'Passkey (FIDO2) settings' and includes a sub-header 'Passkeys (FIDO2) Authentication Methods (Preview)'. A blue information banner states: 'Your organization has opted into public preview for synced passkeys and passkey profiles. Your previous passkey settings have been moved into the def...' with an 'Opt-out of public preview' button. Below this, a paragraph explains that passkeys are phishing-resistant, standards-based passwordless authentication methods. The 'Enable and target' section shows the 'Enable' toggle switch turned 'On'. The 'Include' tab is active, showing a list of targets. A table lists two targets: 'All users' and 'sug_AAD.CA.Inclusion.PrivilegedAccount...'. Each target is associated with a 'Type' (Group) and a 'Passkey profiles (preview)' dropdown menu. The 'All users' target is set to 'Default passkey profile', and the 'sug_AAD.CA.Inclusion.PrivilegedAccount...' target is set to 'Privileged passkey profile'. Each entry in the table has a trash icon for deletion.

Microsoft Entra admin cent... Search resources, services, and docs (G+/)

Home > Authentication methods | Policies >

Passkey (FIDO2) settings

Passkeys (FIDO2) Authentication Methods (Preview)

ⓘ Your organization has opted into public preview for synced passkeys and passkey profiles. Your previous passkey settings have been moved into the def... [Opt-out of public preview](#)

Passkeys are a phishing-resistant, standards-based passwordless authentication method that can be stored on a variety of security key models or passkey providers. Passkeys are not usable in the self-service password reset flow. [Learn more](#)

Enable and target Configure

Enable ☒ On

Include Exclude

+ Add target

Name	Type	Passkey profiles (preview)
All users	Group	Default passkey profile
sug_AAD.CA.Inclusion.PrivilegedAccount...	Group	Privileged passkey profile

Granulare Konfiguration auf Gruppen (!= Tenant)

The screenshot displays the Microsoft Entra admin center interface. The left sidebar shows the navigation menu with 'Authentication methods | Policies' selected. The main content area is titled 'Passkey (FIDO2) settings' and includes a 'Configure' tab. The 'General' section shows 'Allow self-service set-up' is enabled. The 'Passkey profiles' section contains a table with two profiles: 'Default passkey profile' and 'Privileged passkey profile'. The 'Edit passkey profile' pane on the right shows settings for the 'Default passkey profile', including 'Enforce attestation' (disabled), 'Target types' (Device-bound, Synced (preview)), 'Target specific AAGUIDs' (checked), and 'Behavior' (Allow). A list of AAGUIDs is shown, including 'ee882879-721c-4913-9775-3dfcce97072a' and 'c5ef55ff-ad9a-4b9f-h580-adehafa026d0'. A warning message at the bottom states: 'This profile configuration includes type and AAGUID restrictions but attestation is not enforced, so we cannot guarantee the syncability or authenticity of the security key model or passkey provider.'

Microsoft Entra admin cent... Search resources, services, and docs (G+/) Copilot cloudadmin@c4a8ando... C4A8 ANDO (C4A8ANDO.COM)

Home > Authentication methods | Policies > Passkey (FIDO2) settings ...

Passkeys (FIDO2) Authentication Methods (Preview)

ⓘ Your organization has opted into public preview for synced passkeys and passkey profiles.

Passkeys are a phishing-resistant, standards-based passwordless authentication method that is used in the self-service password reset flow. [Learn more](#)

Enable and target **Configure**

General

Allow self-service set-up ⓘ ☒

Passkey profiles

At least one passkey profile must be applied to each target in this policy. The default passkey profile must be applied to all targets.

+ Add profile (preview)

Name	Enforce attestation	Type
Default passkey profile ⚠	No	Device-bound
Privileged passkey profile	Yes	Device-bound

Edit passkey profile

Certain combinations of these settings could target passkeys that may not exist. This can prevent your users from registering and signing in with a passkey. [View compatibility documentation](#)

Name * Default passkey profile

Enforce attestation ⓘ ☐

Target types * Device-bound, Synced (preview) ▾

Target specific AAGUIDs ⓘ ☒

Behavior ⓘ * ☒ Allow ☐ Block

Model/Provider AAGUIDs ⓘ

+ Add AAGUID

ee882879-721c-4913-9775-3dfcce97072a	🗑
Microsoft Authenticator for Android	🗑
Windows Hello VBS Hardware Authenticator	🗑
Windows Hello Hardware Authenticator	🗑
Windows Hello Software Authenticator	🗑
c5ef55ff-ad9a-4b9f-h580-adehafa026d0	🗑

⚠ This profile configuration includes type and AAGUID restrictions but attestation is not enforced, so we cannot guarantee the syncability or authenticity of the security key model or passkey provider. [Learn more](#)

Absicherung von MFA-Registrierung mit CA Policy

Home > Conditional Access | Policies

104 - ALL - User Access - User Action/Register security information: Require MFA or compliant device For internal users

Conditional Access policy

Delete View policy information View policy impact

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
104 - ALL - User Access - User Action/Regis...

Control access based on all or specific apps, agents, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to
User actions

Assignments

Users, agents or workload identities ⓘ
[All users included and specific users excluded](#)

Target resources ⓘ
1 user action included

Network **NEW** ⓘ
[Not configured](#)

Conditions ⓘ
1 condition selected

Access controls

Grant ⓘ
1 control selected

Select the action this policy will apply to

☒ Register security information

☐ Register or join devices

Re-Authentication für Intune Enrollment

Require re-authentication every time

In some scenarios, you may want to require re-authentication for specific actions, such as:

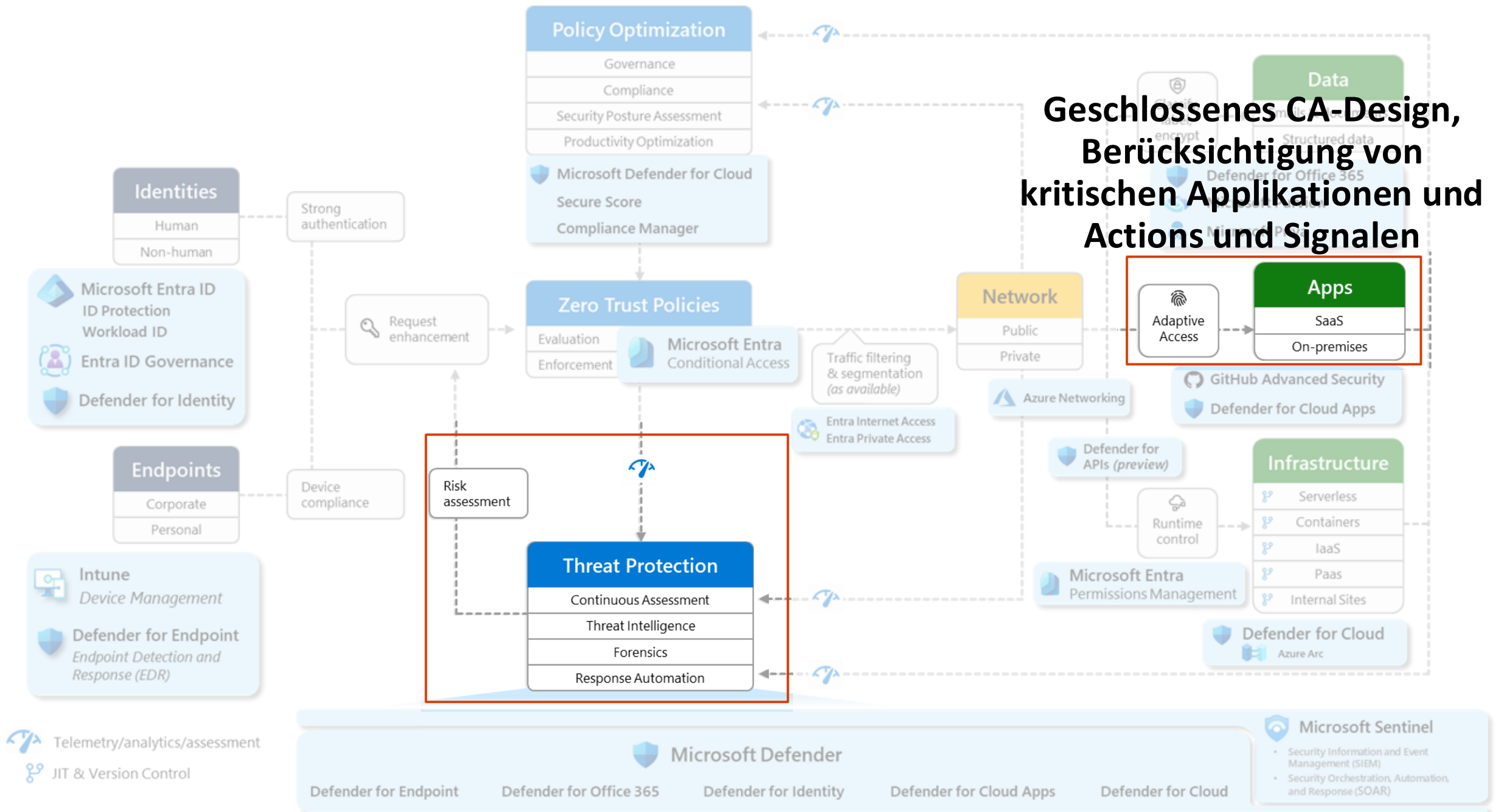
- Accessing sensitive data
- Securing resources
- Securing privileged actions
- Protecting user data
- Protecting risky actions
- Securing sensitive data

Cloud app	MFA prompt location	Automated Device Enrollment notes
Microsoft Intune	Setup Assistant, Company Portal app	With this option, MFA is required during enrollment and each time the user signs into the Company Portal app or website. The MFA prompts appear on the Company Portal sign-in page.
Microsoft Intune Enrollment	Setup Assistant	With this option, MFA is required during device enrollment and appears as a one-time MFA prompt on the Company Portal sign-in page.

ⓘ Note

The Microsoft Intune Enrollment cloud app isn't created automatically for new tenants. To add the app for new tenants, a Microsoft Entra administrator must create a service principal object, with app ID d4ebce55-015a-49b5-a083-c84d1797ae8c, in PowerShell or Microsoft Graph.

Geschlossenes CA-Design, Berücksichtigung von kritischen Applikationen und Actions und Signalen



Conditional Access Baseline Design



Stelle sicher, dass jeder Benutzer und jede App durch mindestens eine minimale aber starke Basislinie geschützt wird!
Vermeide inkonsistente oder doppelte Richtlinien durch ein „smarteres“ und geschlossenes CA-Design!

Ausnahmen und Bypass bei CA (Beispiele)

Protect your resources behind the compliant network

The compliant network Conditional Access policy can be used to protect your Microsoft and third-party applications that are integrated with Entra ID single sign-on. A typical policy will have a 'Block' grant for all network locations except Compliant Network. The following example demonstrates the steps to configure this type of policy:

1. Sign in to the [Microsoft Entra admin center](#) as at least a [Conditional Access Administrator](#).
2. Browse to **Entra ID > Conditional Access**.
3. Select **Create new policy**.
4. Give your policy a name. We recommend that organizations create a meaningful standard for the names of their policies.
5. Under **Assignments**, select **Users or workload identities**.
 - a. Under **Include**, select **All users**.
 - b. Under **Exclude**, select **Users and groups** and choose your organization's [emergency access or break-glass accounts](#).
6. Under **Target resources > Include**, and select **All resources (formerly 'All cloud apps')**.
 - a. If your organization is enrolling devices into Microsoft Intune, it is recommended to [exclude the applications Microsoft Intune Enrollment and Microsoft Intune](#) from your Conditional Access policy to avoid a circular dependency.
7. Under **Network**.
 - a. Set **Configure** to **Yes**.
 - b. Under **Include**, select **Any location**.
 - c. Under **Exclude**, select the **All Compliant Network locations** location.
8. Under **Access controls**:
 - a. **Grant**, select **Block Access**, and select **Select**.
9. Confirm your settings and set **Enable policy** to **On**.
10. Select the **Create** button to create to enable your policy.

Conditional Access behavior when an all resources policy has an app exclusion

If any app is excluded from the policy, in order to not inadvertently block user access, certain low privilege scopes are excluded from policy enforcement. These scopes allow calls to the underlying Graph APIs, like **Windows Azure Active Directory** (00000002-0000-0000-c000-000000000000) and **Microsoft Graph** (00000003-0000-0000-c000-000000000000), to access user profile and group membership information commonly used by applications as part of authentication. For example: when Outlook requests a token for Exchange, it also asks for the **User.Read** scope to be able to display the basic account information of the current user.

Most apps have a similar dependency, which is why these low privilege scopes are automatically excluded whenever there's an app exclusion in an **All resources** policy. These low privilege scope exclusions don't allow data access beyond basic user profile and group information. The excluded scopes are listed as follows, consent is still required for apps to use these permissions.

- Native clients and Single page applications (SPAs) have access to the following low privilege scopes:
 - Azure AD Graph: **email**, **offline_access**, **openid**, **profile**, **User.Read**
 - Microsoft Graph: **email**, **offline_access**, **openid**, **profile**, **User.Read**, **People.Read**
- Confidential clients have access to the following low privilege scopes, if they're excluded from an **All resources** policy:
 - Azure AD Graph: **email**, **offline_access**, **openid**, **profile**, **User.Read**, **User.Read.All**, **User.ReadBasic.All**
 - Microsoft Graph: **email**, **offline_access**, **openid**, **profile**, **User.Read**, **User.Read.All**, **User.ReadBasic.All**, **People.Read**, **People.Read.All**, **GroupMember.Read.All**, **Member.Read.Hidden**

Ausnahmen und Bypass bei CA (Beispiele)

Upcoming Conditional Access change: Improved enforcement for policies with resource exclusions



Swaroop Krishnamurthy  MICROSOFT

Jan 28, 2026

We're strengthening how Microsoft Entra Conditional Access is enforced for a narrow set of authentication flows to improve your security posture.

In alignment with [Microsoft's Secure Future Initiative](#), we are taking the following proactive security measures for defense-in-depth. Please review the changes and take any required actions to prepare.

What is changing?

- **Today**, when a user signs in through a client application that requests **only** [OIDC scopes](#) or a [limited set of directory scopes](#), Conditional Access policies that target *All resources* are not enforced **if the policy has one or more resource exclusions**.
- **After this change**, Conditional Access policies that target *All resources* **will be enforced** for these sign-ins, **even when resource exclusions are present**. This ensures that policies are consistently applied regardless of the scope set requested by the application. [Read more about this change](#).

Research EntraScopes.com

Entra ID First Party Apps & Scope Browser

Browse and explore first-party applications including their pre-consented permissions in Microsoft Entra ID

Filters

Search

Search apps...

FOCI Status

FOCI and Non-FOCI

Client Type

All Client Types

BroCI / NAA

All Apps

Conditional Access Bypass

All

App IDs

Select App IDs

Resources

Select Resources

Scopes

Select Scopes

AuthCodeFix/ConsentFix

All

Microsoft_Azure_ELMAdmin

Non-FOCI BroCI (NAA)

App ID: 0032593d-6a05-4847-8ca4-4b6220ed2a1e

6 Resources 21 Scopes 9 URIs

RESOURCES:

Microsoft Graph

00000003-0000-0000-c000-000000000000

16 scopes

Azure AD Identity Governance - Entitlement Management

810dcf14-1858-4bf2-8134-4c369fa3235b

1 scope

Microsoft Rights Management Services

00000012-0000-0000-c000-000000000000

1 scope

Office 365 Management

FOCI Public Client CA Bypass (1)

App ID: 00b41c95-dab0-4487-9791-b9d2c32c80f2

91 Resources 113 Scopes 33 URIs

RESOURCES:

Microsoft Graph

00000003-0000-0000-c000-000000000000

13 scopes

Unknown Resource

93aca3ff-e61e-477f-b3e7-9fe10c6b97af

1 scope

Aadrm Admin Powershell

90f610bf-206d-4950-b61d-37fa6fd1b224

1 scope

CloudNativeTesting Portal

Non-FOCI BroCI (NAA)

App ID: 00daac17-a7ce-4990-a494-a7120e0b5c6c

4 Resources 9 Scopes 7 URIs

RESOURCES:

Azure DevOps

499b84ac-1321-427f-aa17-267ca6975798

6 scopes

CloudNativeTesting

847bd4c1-7486-4241-a783-f9bda69241c1

1 scope

Microsoft Rights Management Services

00000012-0000-0000-c000-000000000000

1 scope

Risk Remediation for Passwordless users

Microsoft-managed remediation risk-based Conditional Access policy to manage the appropriate remediation flow based on the threat observed and authentication method

The screenshot displays the Microsoft Entra admin center interface. The main navigation pane on the left includes links for Home, Conditional Access | Policies, and various other administrative functions. The central pane shows the configuration for a policy named "Identity Protection 1 - User-risk require risk remediation". The policy is currently in a "Grant" state, with 1 control selected. The configuration details include:

- Name:** Identity Protection 1 - User-risk require risk ...
- Assignments:** Users, agents or workload identities (1). All users included and specific users excluded.
- Target resources:** All resources (formerly 'All cloud apps').
- Network:** NEW. Not configured.
- Conditions:** 1 condition selected.
- Access controls:** Grant (1). 1 control selected.
- Session:** Sign-in frequency - Every time.

The right-hand pane, titled "Grant", shows the following settings:

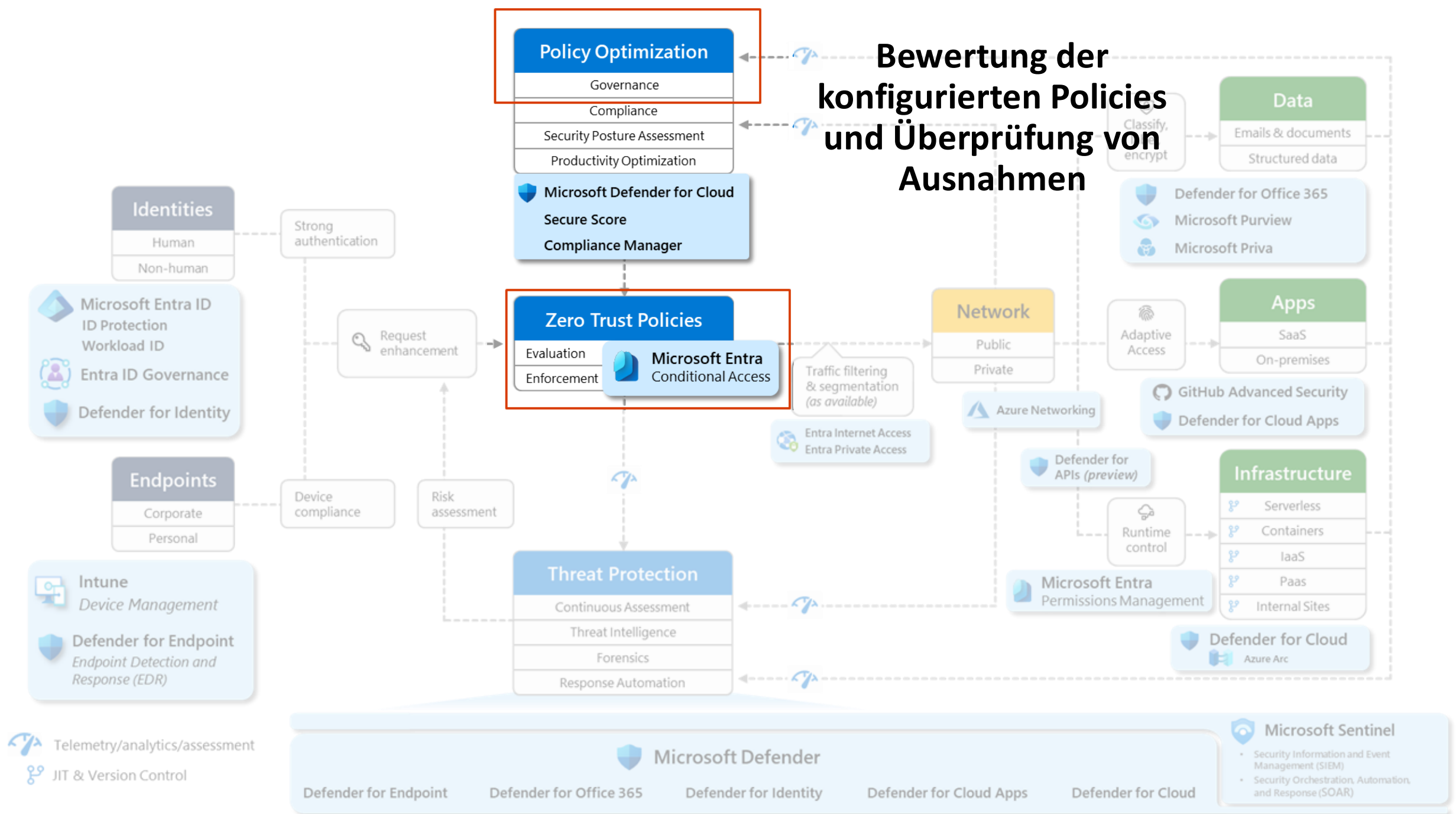
- ☒ Require authentication strength (1). Phishing-resistant MFA (selected).
- ☐ Require device to be marked as compliant (1).
- ☐ Require Microsoft Entra hybrid joined device (1).
- ☐ Require approved client app (1). See list of approved client apps.
- ☐ Require app protection policy (1). See list of policy protected client apps.
- ☐ Require password change (1).
- ☒ Require risk remediation (1).

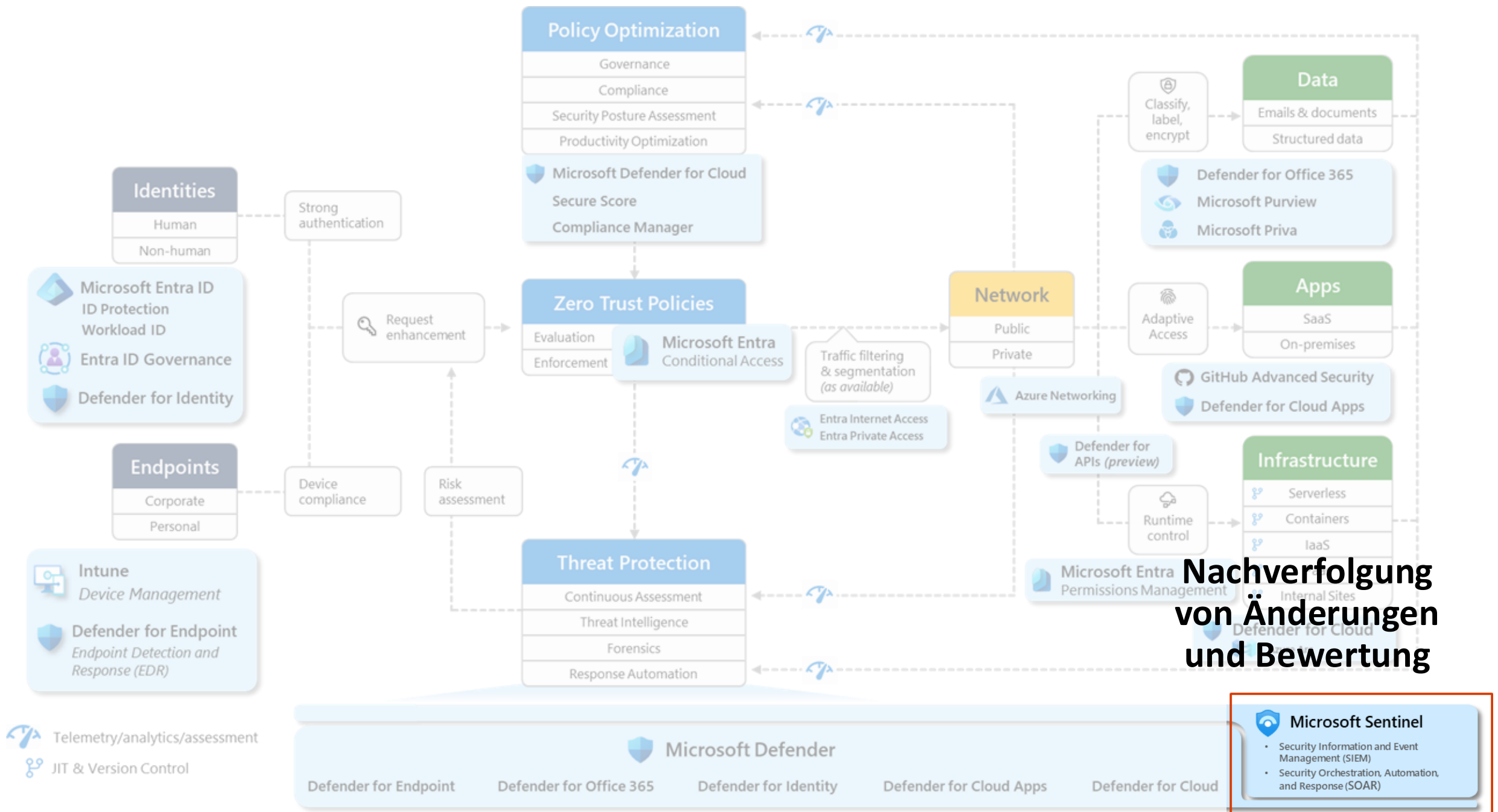
An information box states: "To require phishing-resistant authentication for external users, configure cross-tenant access settings to accept claims from Microsoft Entra tenants. [Learn more](#)".

A warning message at the bottom right states: "Require risk remediation" can only be used when policy is...

The user profile in the top right corner is cloudadmin@c4a8ando... (C4A8 ANDO (C4A8ANDO.COM)).

Bewertung der konfigurierten Policies und Überprüfung von Ausnahmen





**Nachverfolgung
von Änderungen
und Bewertung**

Conditional Access "WhatIf"

Dashboard > Security | Conditional Access > Conditional Access | Policies >

What If ...

Policies

[Info](#) [Preview features](#) [Got feedback?](#)

Test the impact of Conditional Access on a user when signing in under certain conditions. [Learn more](#)

User or Workload identity ⓘ

[No user or service principal selected](#)

✖ **User or Service principal required**

Cloud apps, actions, or authentication context ⓘ

[Any cloud app](#)

IP address ⓘ

Enter IP address (ex: 40.77.182.32)

Country ⓘ

Select country...

Device platform ⓘ

Select device platform...

Client apps ⓘ

Select a client app...

Device state (deprecated) ⓘ

Select device state...

Sign-in risk ⓘ

Select sign-in risk...

User risk ⓘ

Select user risk...

Service principal risk ⓘ

Select service principal risk...

Learn / Microsoft.Graph.Beta.Identity.SignIns /

Test-MgBetaIdentityConditionalAccess

Reference

[Feedback](#)

Module: [Microsoft.Graph.Beta.Identity.SignIns](#)

Invoke action evaluate

Syntax

PowerShell

[Copy](#)

```
Test-MgBetaIdentityConditionalAccess
  [-ResponseHeadersVariable <String>]
  [-AdditionalProperties <Hashtable>]
  [-AppliedPoliciesOnly]
  [-ConditionalAccessContext <Hashtable>]
  [-ConditionalAccessWhatIfConditions
  <IMicrosoftGraphConditionalAccessWhatIfConditions>]
  [-ConditionalAccessWhatIfSubject <Hashtable>]
  [-Headers <IDictionary>]
  [-ProgressAction <ActionPreference>]
  [-WhatIf]
  [-Confirm]
  [<CommonParameters>]
```

Maester Checks for CA "WhatIf"

```
Describe "Contoso.ConditionalAccess" {  
    It "SharePoint requires MFA" {  
  
        $userId = (Get-MgUser -UserId 'john@contoso.com').Id  
        $SharePointAppId = '67ad5377-2d78-4ac2-a867-6300cda00e85'  
  
        $policiesEnforced = Test-MtConditionalAccessWhatIf -UserId $userId `  
            -IncludeApplications $SharePointAppId  
  
        $policiesEnforced.grantControls.builtInControls | Should -Contain "mfa"  
    }  
}
```



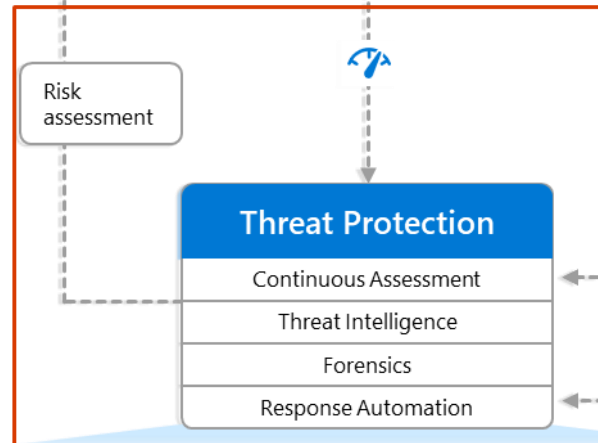
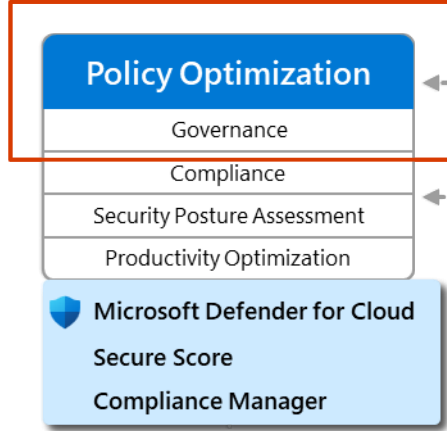
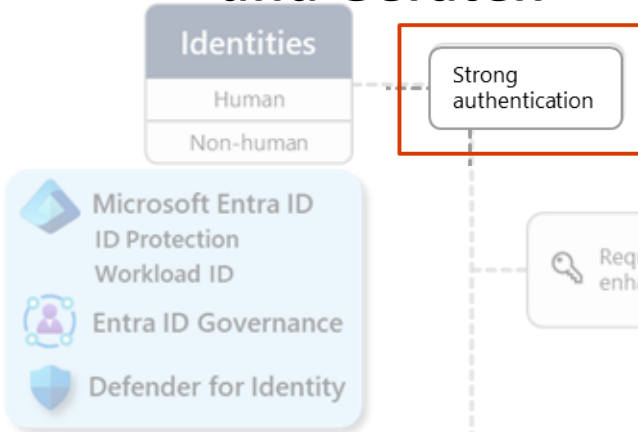
Hands-on Conditional Access:

2.1 Analyse von Conditional Access
mit Maester

2.2 Microsoft MCP Enterprise Server
zum Review von CA Policies

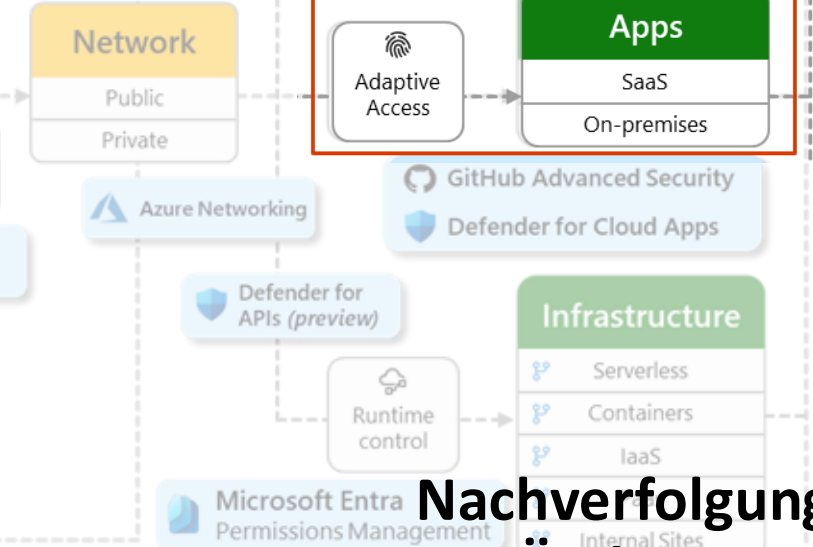
2.3 Conditional Access Bypasses

Absicherung der Registrierung von MFA und Geräten



Verwaltung von Ausnahmen

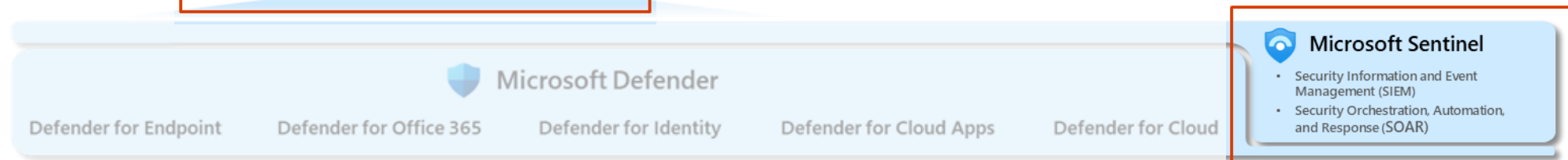
Geschlossenes CA-Design, Berücksichtigung von kritischen Applikation und Actions und Signalen



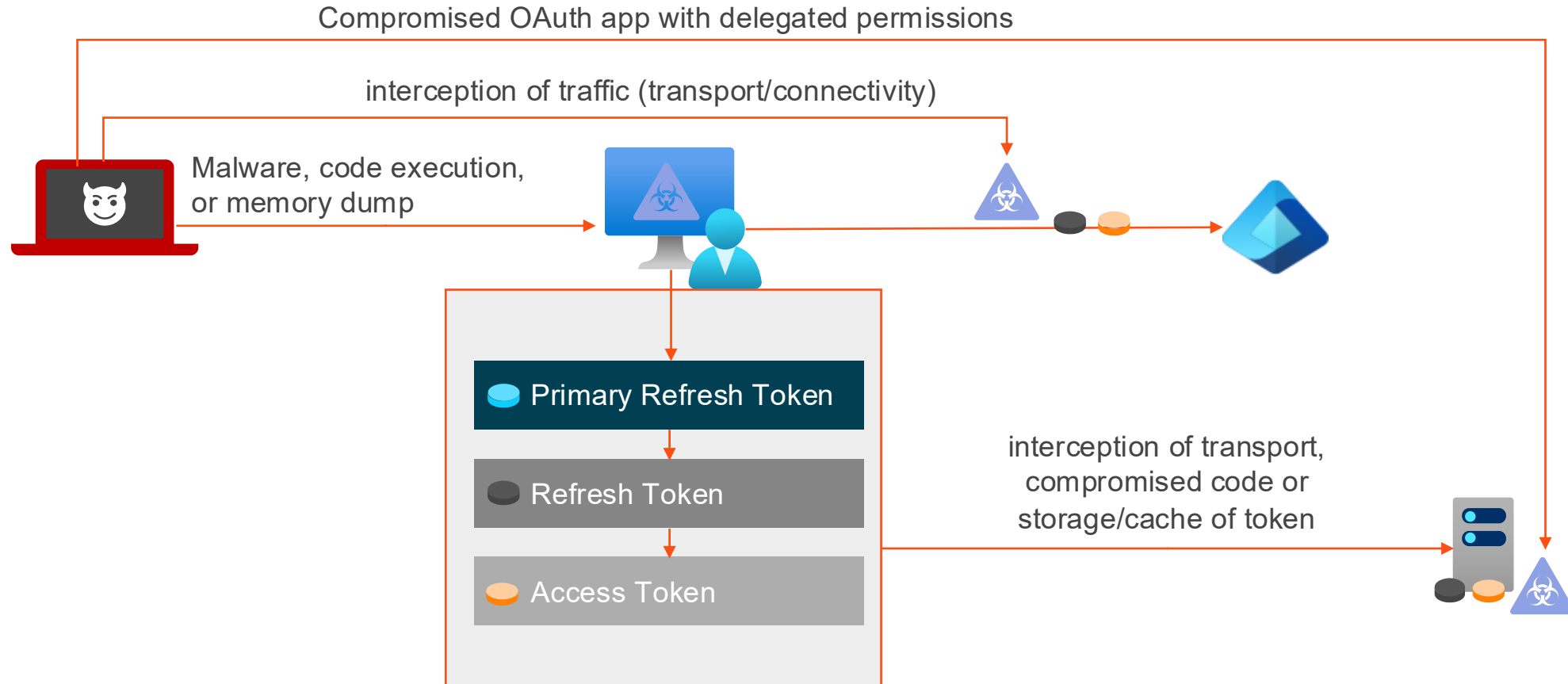
Nachverfolgung von Änderungen und Bewertung

Telemetry/analytics/assessment

JIT & Version Control



Post Authentication Attacks (trotz gutem CA Policy Design)





Demo

Consent Fix Attack

Consent Fix & FOCI Member

**Microsoft Azure PowerShell**

1950a258-227b-4e31-a9cf-717495945fc2

	Microsoft Graph	Directory.AccessAsUser.All
	Azure AD	Global Administrator
	Azure RM	user_impersonation
	Other API*	user_impersonation
Azure DevOps		

"Microsoft Azure PowerShell" has pre-consented access to a wide range of resources. It can read all audit logs in Microsoft Entra, access all user data, impersonate users in Azure DevOps, Azure Resource Manager, Microsoft Teams and Microsoft Whiteboard. It also has access to Bing and Power Platform APIs.



Dirk-Jan Mollema

6d

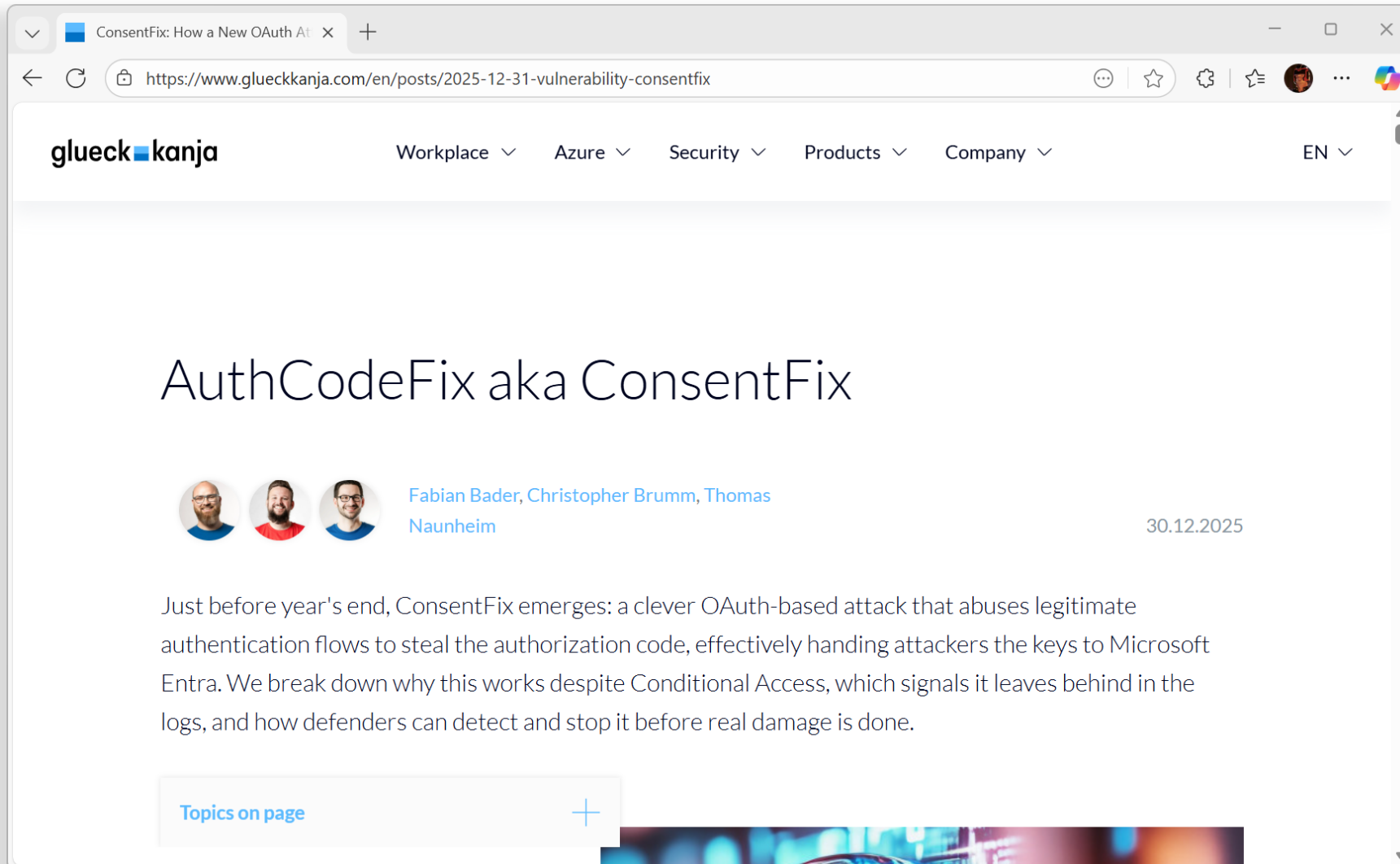


I can't believe Microsoft killed off one of my favorite labs in my Entra ID course 😭. Since last week, the Azure CLI and Azure PowerShell clients are no longer part of the Family of Client IDs (FOCI), which means that their refresh tokens cannot be reused for other apps. On a serious note: this is of course good for security, never really understood why these were FOCI clients in the first place since most of the other ones are mobile/office focused.



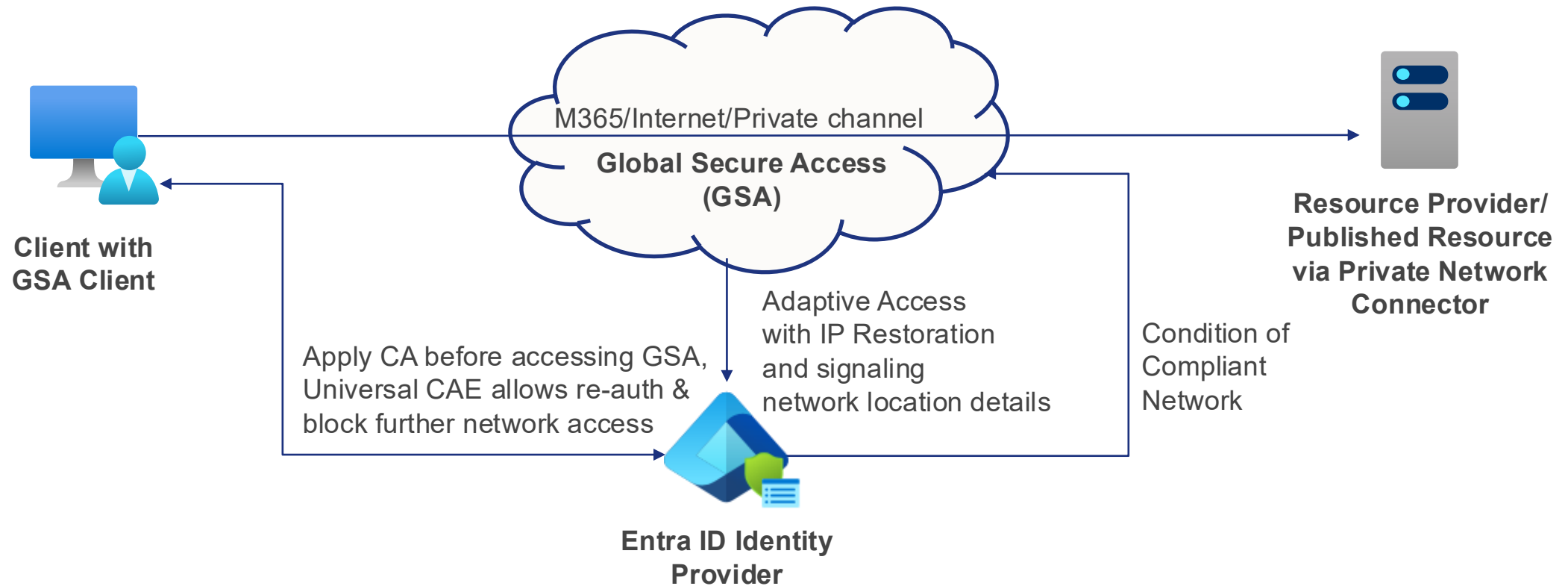
576 · 17 Comments

Consent Fix Detections and Mitigations

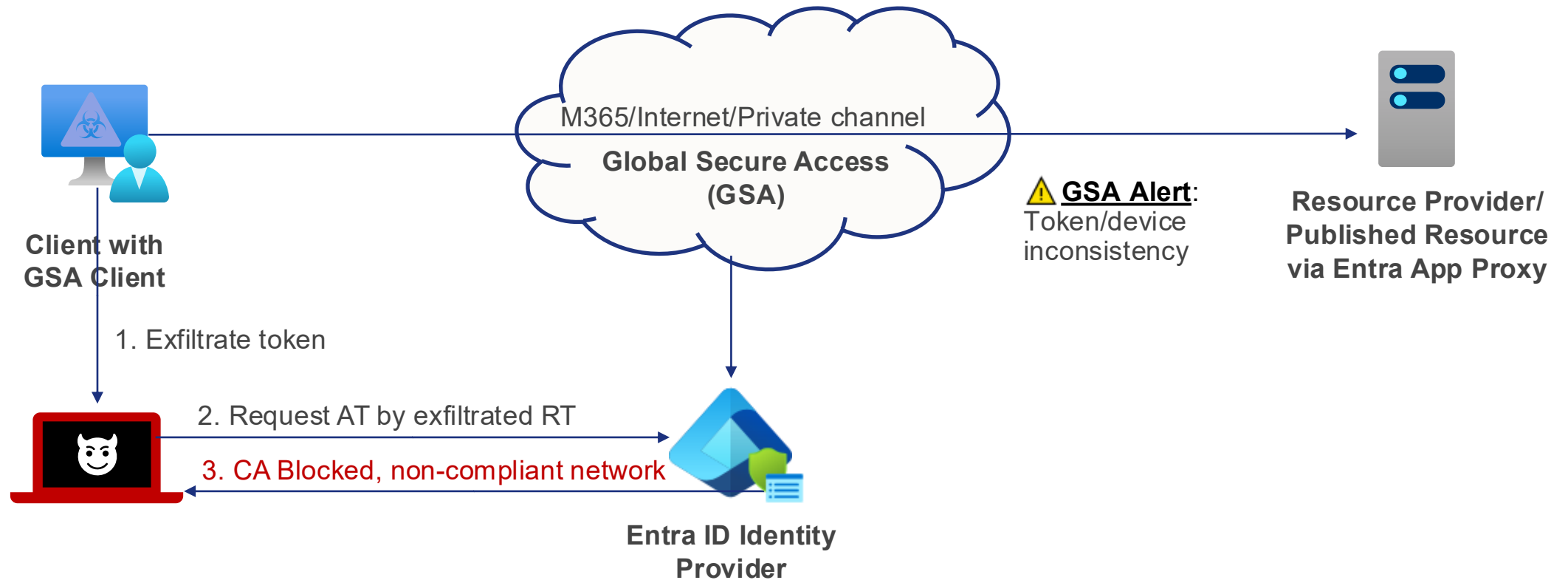


Source: [AuthCodeFix aka ConsentFix](#)

Compliant Network + Global Secure Access



Compliant Network + Global Secure Access





Microsoft Entra Internet Access for Microsoft Services

Licensing overview

Microsoft Entra Internet Access, Microsoft Entra Internet Access for Microsoft services, and Microsoft Entra Private Access are now generally available.

- Microsoft Entra Internet Access capabilities are included in the Microsoft Entra Suite license and standalone. Microsoft Entra Internet Access helps you secure access to all internet and SaaS applications.
- Microsoft Entra Private Access capabilities are included in the Microsoft Entra Suite license and standalone. Microsoft Entra Private Access elevates network security with a Zero Trust Network Access (ZTNA) solution.
- Microsoft Entra Internet Access for Microsoft services capabilities are included in a Microsoft Entra ID P1 or Microsoft Entra ID P2 license. Microsoft Entra Internet Access for Microsoft services enhances Microsoft Entra ID capabilities with direct connectivity to supported Microsoft services, improving security, performance, and resilience.

Authentication Context & Step-up Auth.

Dashboard > Privileged Identity Management | Azure resources > Landing Zone - Mod

Edit role setting - Virtual Machine Contributor

Privileged Identity Management | Azure resources

Activation Assignment Notification

Activation maximum duration (hours)

8

On activation, require

☐ None

☐ Azure MFA

☒ Microsoft Entra Conditional Access authentication context

Learn more

Require Reauthentication

☒ Require justification on activation

☐ Require ticket information on activation

☐ Require approval to activate

Select approver(s)

... >

Authentication Context - PI

Conditional Access policy

Delete View policy information

Assignments

Users or workload identities

All users included and specific users excluded

Target resources

3 authentication contexts included

Network NEW

Not configured

Conditions

0 conditions selected

Access controls

Grant

1 control selected

Session

Sign-in frequency - Every time

Session

Control access based on session controls to enable limited experiences within specific cloud applications. Learn more

☐ Use app enforced restrictions

This control only works with supported apps. Currently, Office 365, Exchange Online, and SharePoint Online are the only cloud apps that support app enforced restrictions. Learn more

☐ Use Conditional Access App Control

☒ Sign-in frequency

Periodic reauthentication

Every time

☐ Persistent browser session

☐ Customize continuous access evaluation

☐ Disable resilience defaults

Activate - Virtual Machine Contributor

Privileged Identity Management | Azure resources

A Conditional Access policy is enabled and may require additional verification. Click to continue

Roles Activate Scope Status

☐ Custom activation start time

Duration (hours)

8

Reason (max 500 characters) *

Activate Cancel

Authentication Context & Protected Actions

Home > All roles > Enterprise applications | All applications > Roles and administrators | Protected actions >

Add protected actions

Select a Conditional Access authentication context and then the permissions you want to protect with that authentication context. [Learn more](#)

Conditional Access authentication context ... Require Reauthentication

Permissions

+ Select permissions

Description
Update basic properties for Conditional Access policies
Create Conditional Access policies
Delete Conditional Access policies
Delete cross-tenant access policy for partners
Update tenant restrictions of cross-tenant access policy for partners
Permanently delete objects, which can no longer be restored
Update basic properties of custom rules that define network locations
Create custom rules that define network locations
Update Conditional Access authentication context of Microsoft 365

Save

Home > Conditional Access | Policies >

Authentication Context: Require S...

Conditional Access policy

Delete View policy information View policy impact

Target resources

3 authentication contexts included

Network

Not configured

Conditions

1 condition selected

Access controls

Grant

Block access

Session

Sign-in frequency - Every time

Filter for devices

Exclude filtered devices from policy

Authentication

Not configured

Over-prompting users can occur when the "Sign-in Frequency" policy is enabled.

Enable policy

Report-only On Off

Save

Filter for devices

Configure a filter to apply policy to specific devices. [Learn more](#)

Configure

Yes No

Microsoft recommends using at least one system-defined or administrative property.

Devices matching the rule:

Include filtered devices in policy

Exclude filtered devices from policy

You can use the rule builder or rule syntax text box to create or edit a rule.

And/Or	Property	Operator
	extensionAttribute1	Equals
And	isCompliant	Equals

+ Add expression

Rule syntax

device.extensionAttribute1 -eq "SAW" -and device.isCompliant -eq true

Done

More activity in the audit log → Dismiss all

Failed to permanently delete user

Insufficient privileges to permanently delete the selected users.

a few seconds ago

Principal name ↕

8e4cb5...

3d14f1...

96542e...

99541ff...

738b47f...

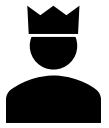


Privilegierte Zugriff:

Administrative Konten und Delegierungen



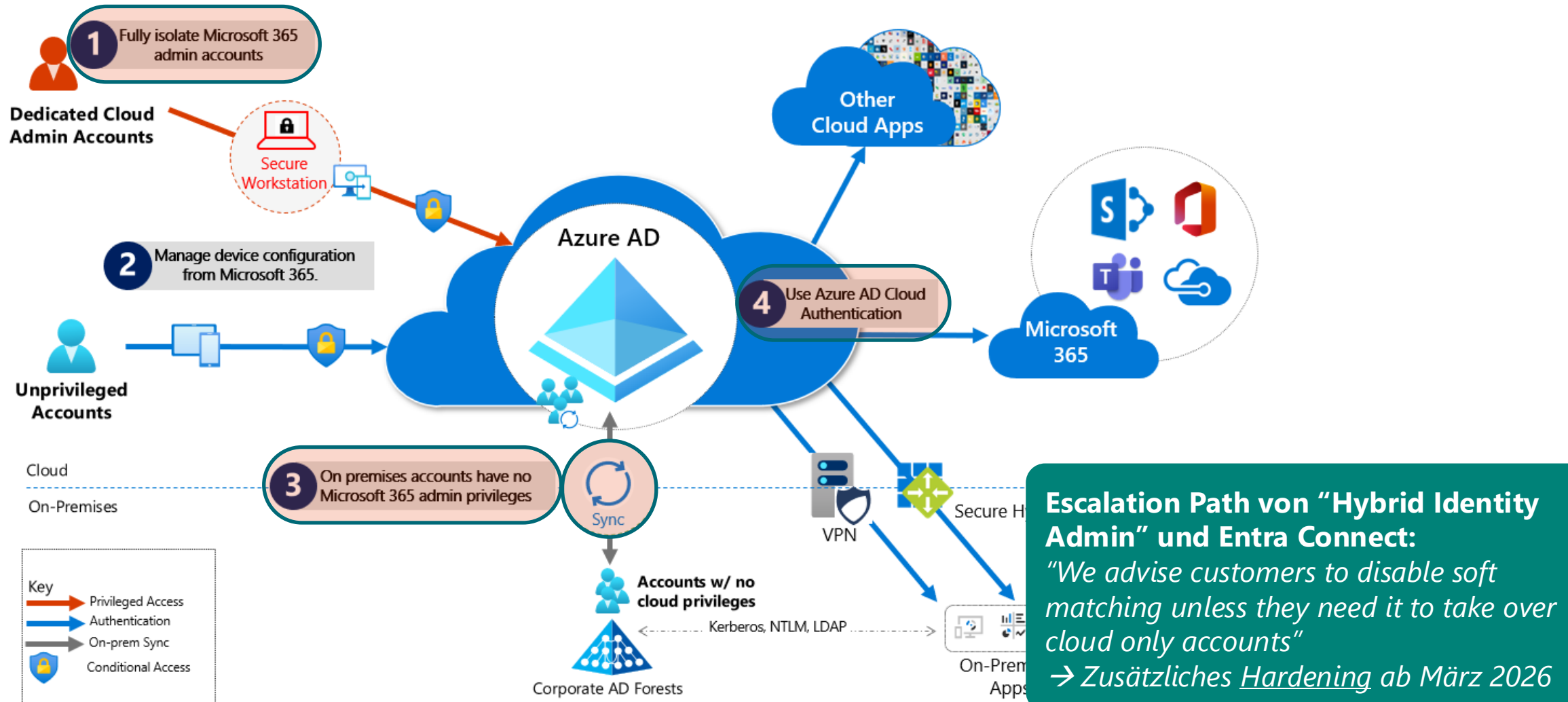
Goldene Regeln für Privilegierten Zugriff



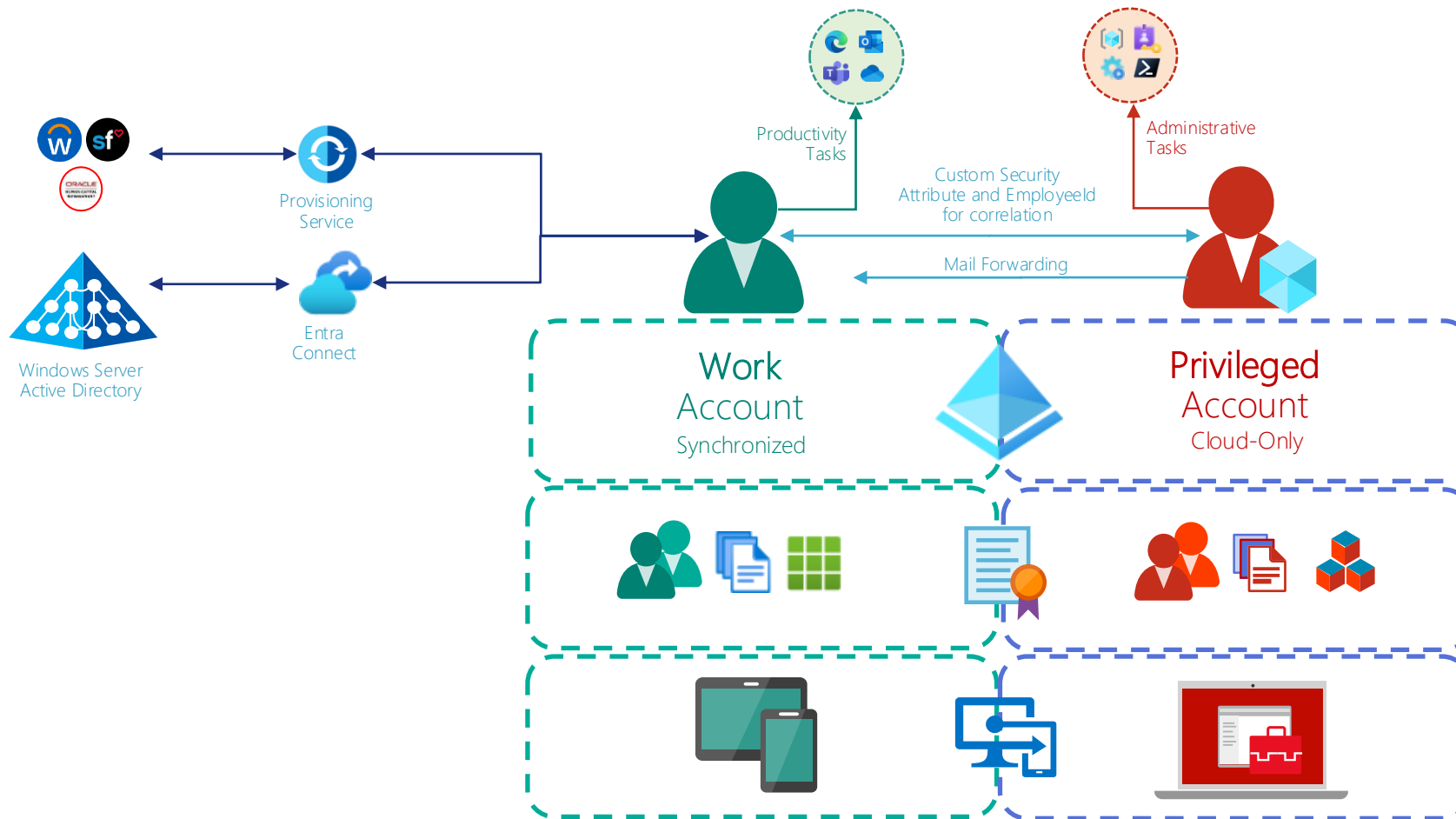
Trennung der Benutzerkonten

Stelle sicher, dass administrative (privilegierte) Konten von Standard-Benutzerkonten getrennt sind, um das Risiko einer Kompromittierung u.a. durch Internet- und E-Mail-Zugriffe zu verhindern.

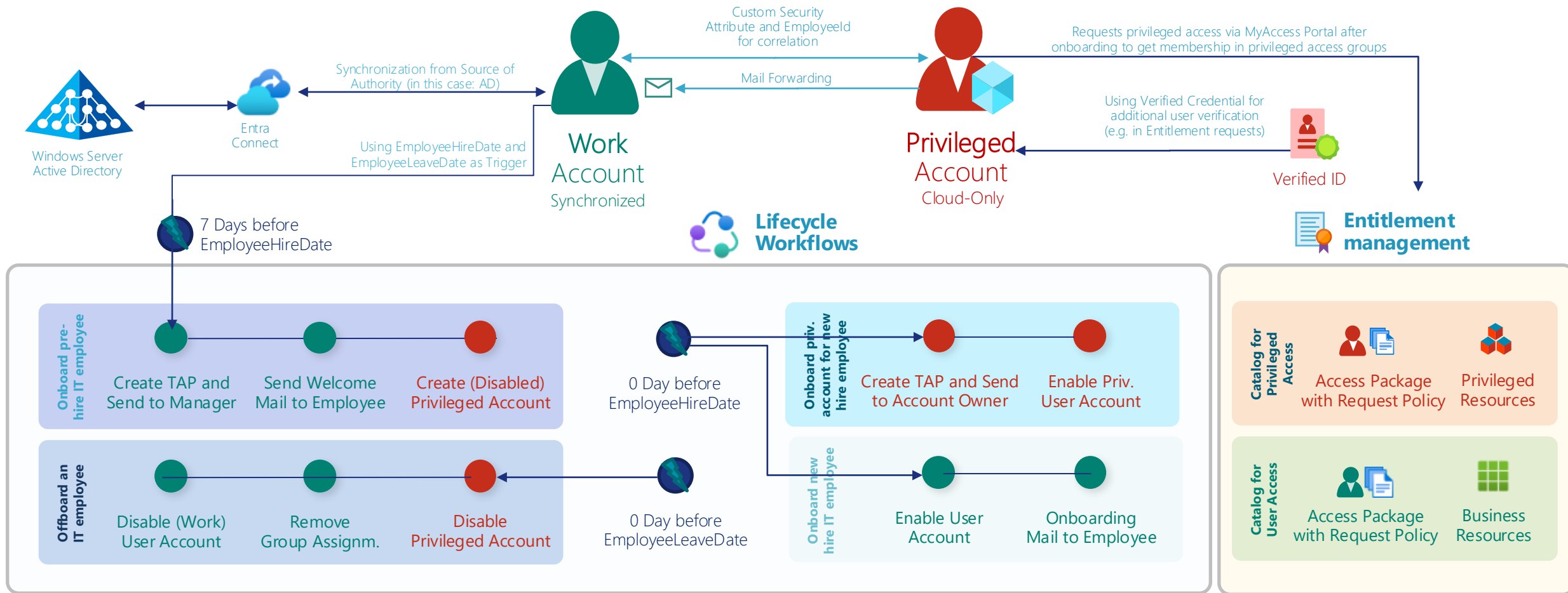
Isolierung von M365/Azure und On-Premises



Grundlage von Privilegierten Konten



Provisionierung von Privilegierten Konten



Provisionierung von Privilegierten Konten



Lifecycle Workflows und Custom Logic App

Vorteil: Direkte Automatisierung und Bindung an Lifecycle des "Work Accounts"

Nachteil: Filter/Condition erforderlich, Benötigt Entra ID Governance P2 Lizenz



Access Package Request und Logic App as Custom Extension

Vorteil: Flexibilität und Prozess-Steuerung für Bereitstellung von Adminkonten

Nachteil: Request notwendig, Offboarding Trigger muss separat implementiert werden

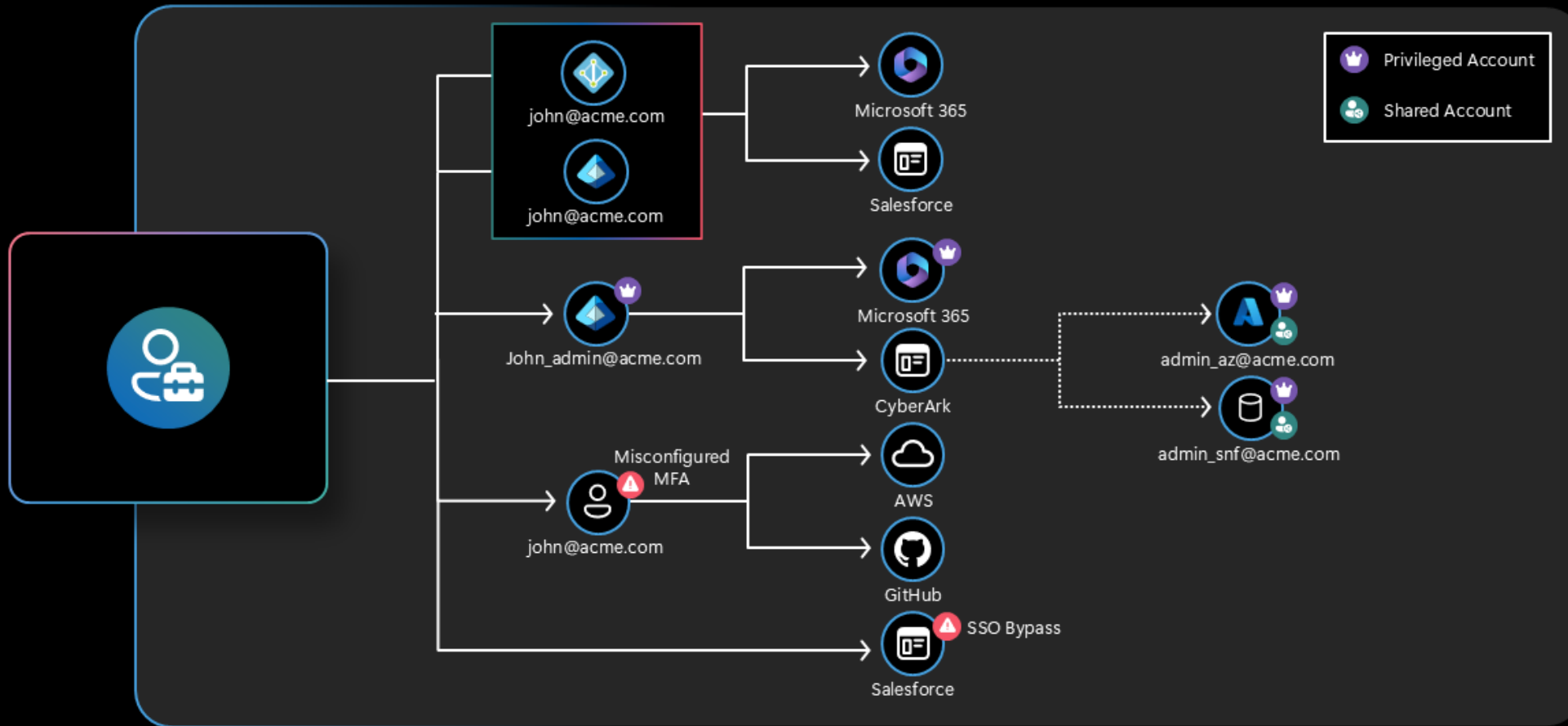


API-driven inbound provisioning mit Logic App, PowerShell or anderem low-code client

Vorteil: Hohe Flexibilität, vollwertiger Sync Prozess, direkte Integration von HR-Datenquelle

Nachteil: Aufwand für Customizing bzw. Integration von API-Client

Linked Identities in Microsoft Defender XDR





Hands-on Privileged Access:

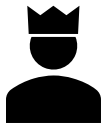
3.1 Checks für privilegierte Benutzer mit Maester

3.2 Identity Details in Microsoft Defender XDR Advanced Hunting

3.3 Privilegiertes Konto mit Identität verknüpfen



Goldene Regeln für Privilegierten Zugriff



Trennung der Benutzerkonten

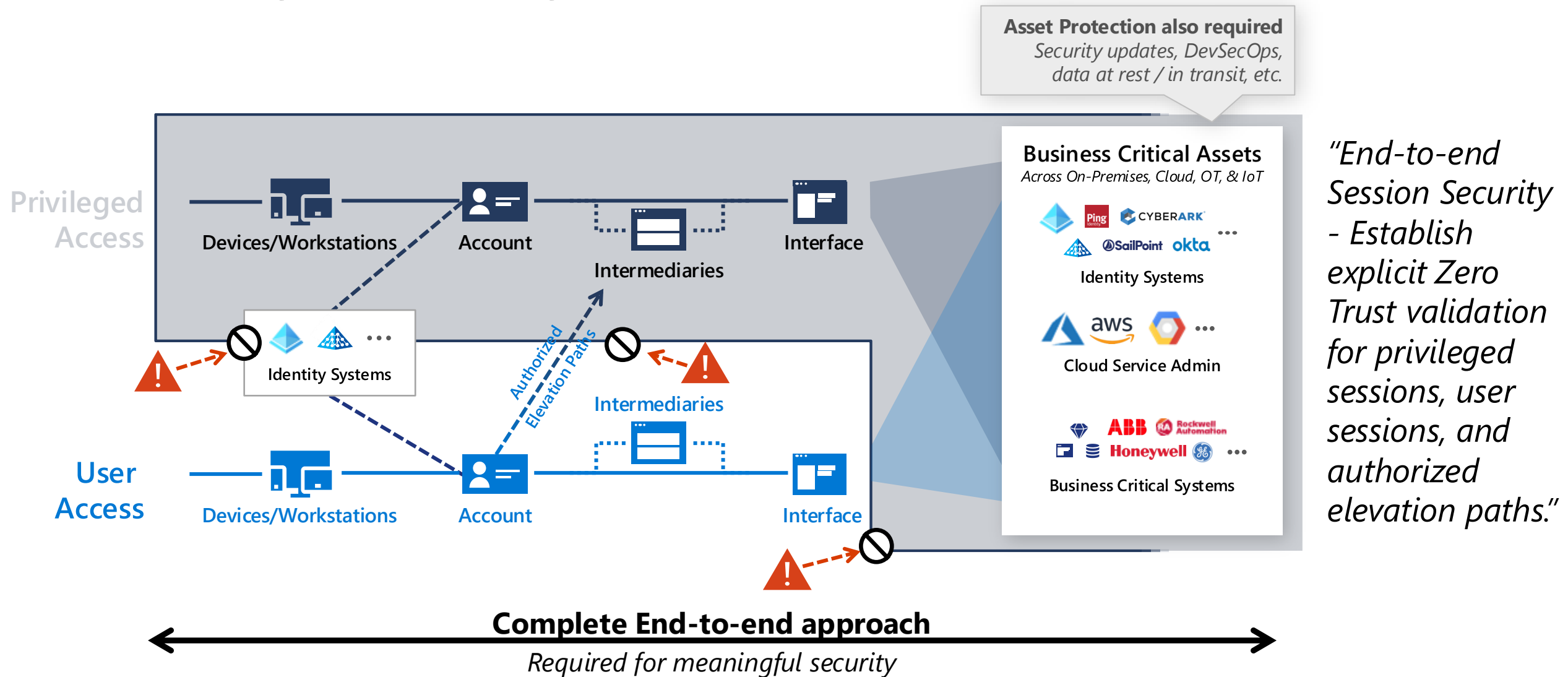
Stelle sicher, dass administrative (privilegierte) Konten von Standard-Benutzerkonten getrennt sind, um das Risiko einer Kompromittierung u.a. durch Internet- und E-Mail-Zugriffe zu verhindern.



Starke Sicherheitsrichtlinien

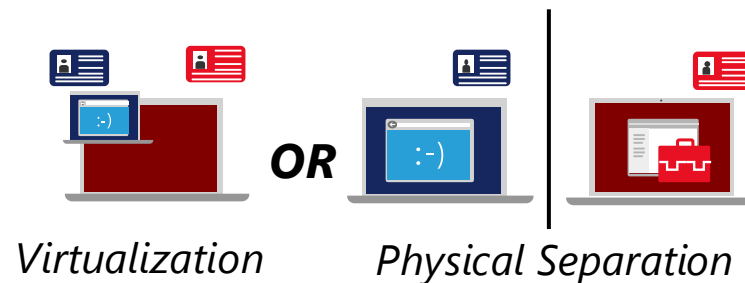
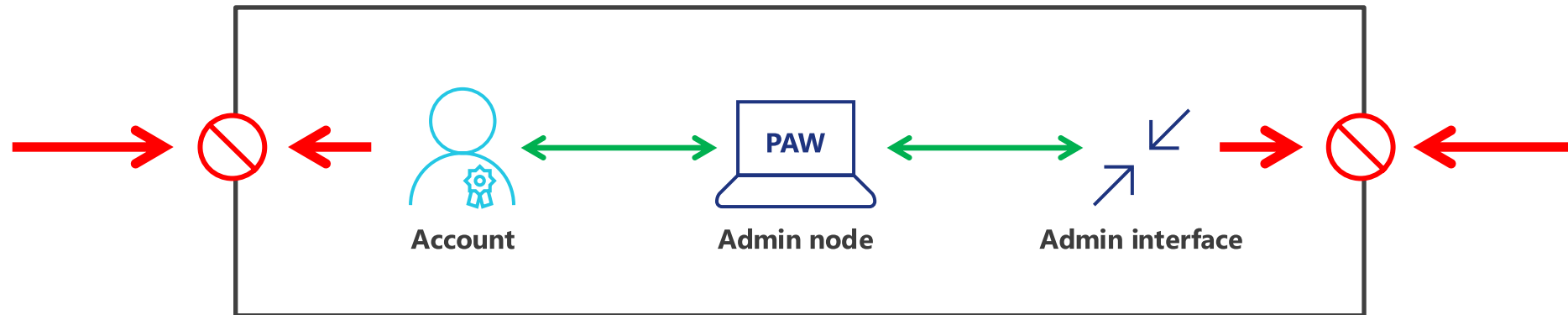
Erzwinge Phishing-resistente Authentifizierung, Device Compliance- und Filter, um den Zugriff auf privilegierte Interfaces nur von autorisierten Endpoints zu gestatten

Privilegierte Zugriffspfade



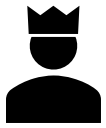
Privilegierte Endpunkte

- **DISA STIG** requires Privilege Access Workstations (PAW) for Cloud Tenant Management
- **CIS (C4)**: Administrators shall use a dedicated, isolated machine for all administrative tasks
- **Azure Security Benchmark (PA-6)**: Use privileged access workstations (Secured, isolated workstations...)





Goldene Regeln für Privilegierten Zugriff



Trennung der Benutzerkonten

Stelle sicher, dass administrative (privilegierte) Konten von Standard-Benutzerkonten getrennt sind, um das Risiko einer Kompromittierung u.a. durch Internet- und E-Mail-Zugriffe zu verhindern.



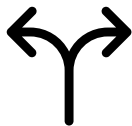
Starke Sicherheitsrichtlinien

Erzwinge phishing-resistente Authentifizierung, Device Compliance- und Filter, um den Zugriff auf privilegierte Interfaces nur von autorisierten Endpoints zu gestatten



Eingeschränkte Delegation

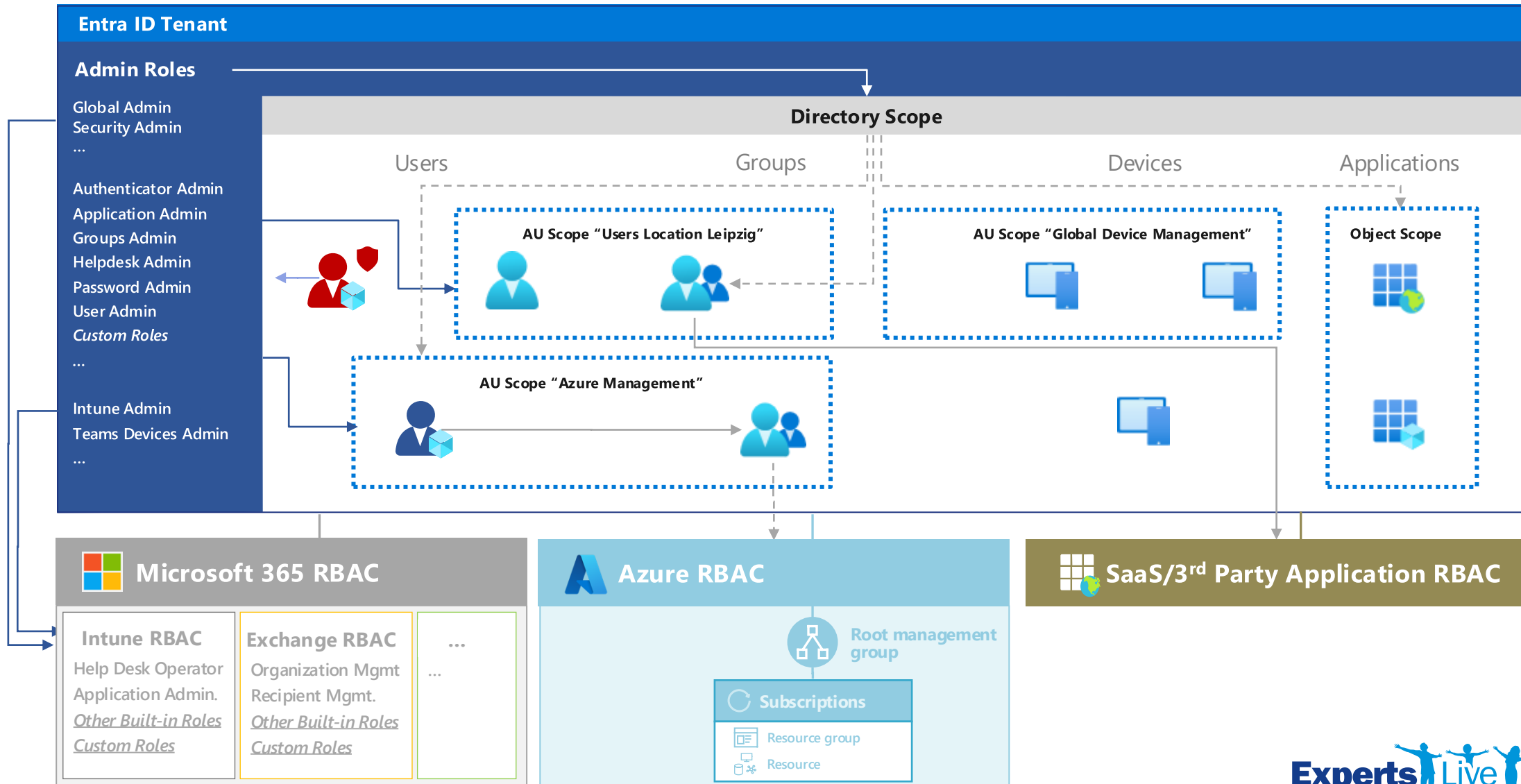
Verwenden „Restricted Management Administrative Units“ und/oder rollen-zuweisbare Gruppen, um den Zugriff auf die privilegierten Objekte einzuschränken.



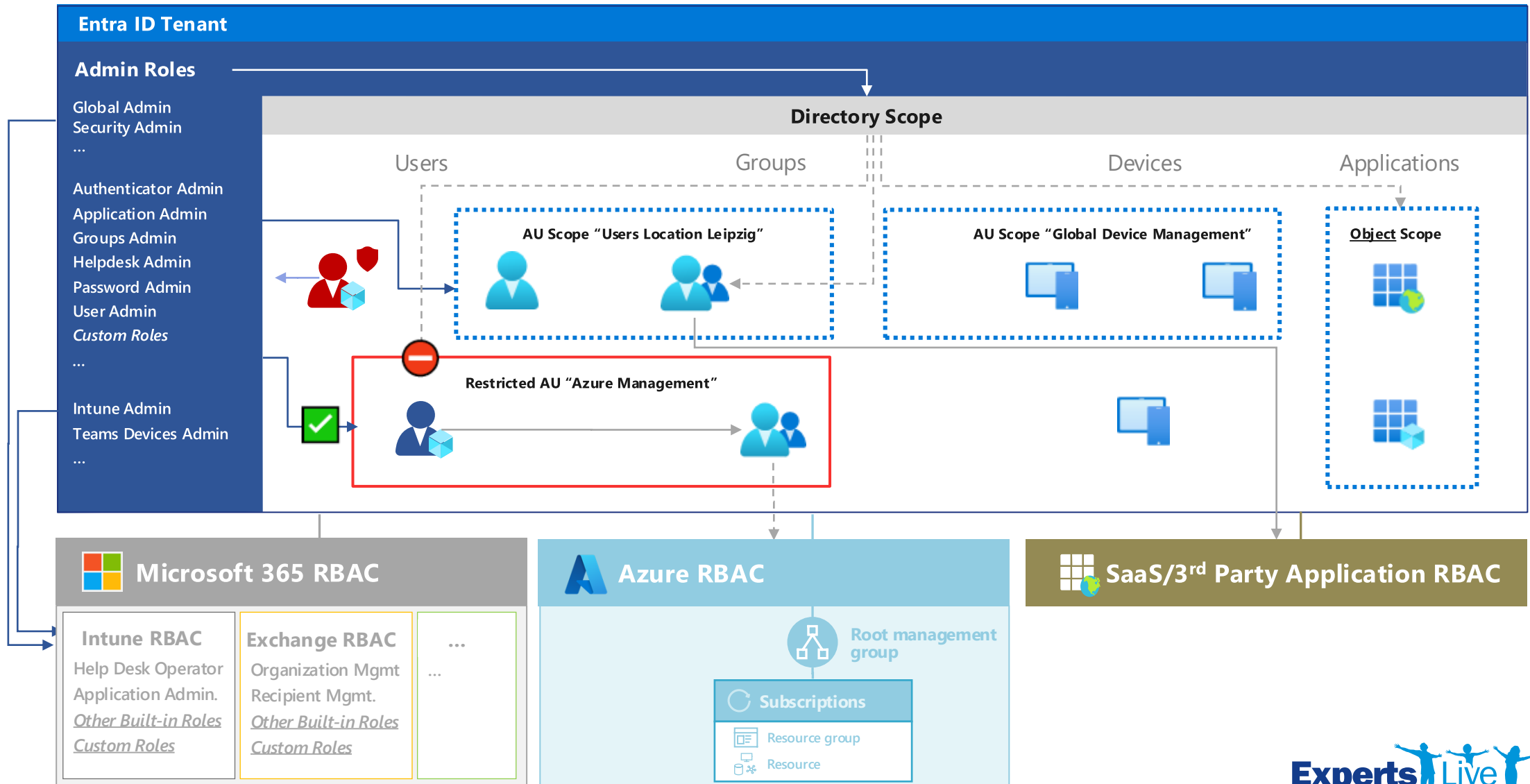
Tiered Administration

Erstellen eine klare Klassifizierung sensibler Rollen und deren Geltungsbereiche, um administrative Zugriffsbereiche zu segmentieren.

Delegierungen und Schutz von Privilegierten Objekten



Delegierungen und Schutz von Privilegierten Objekten



Identity Governance for Privileged Access



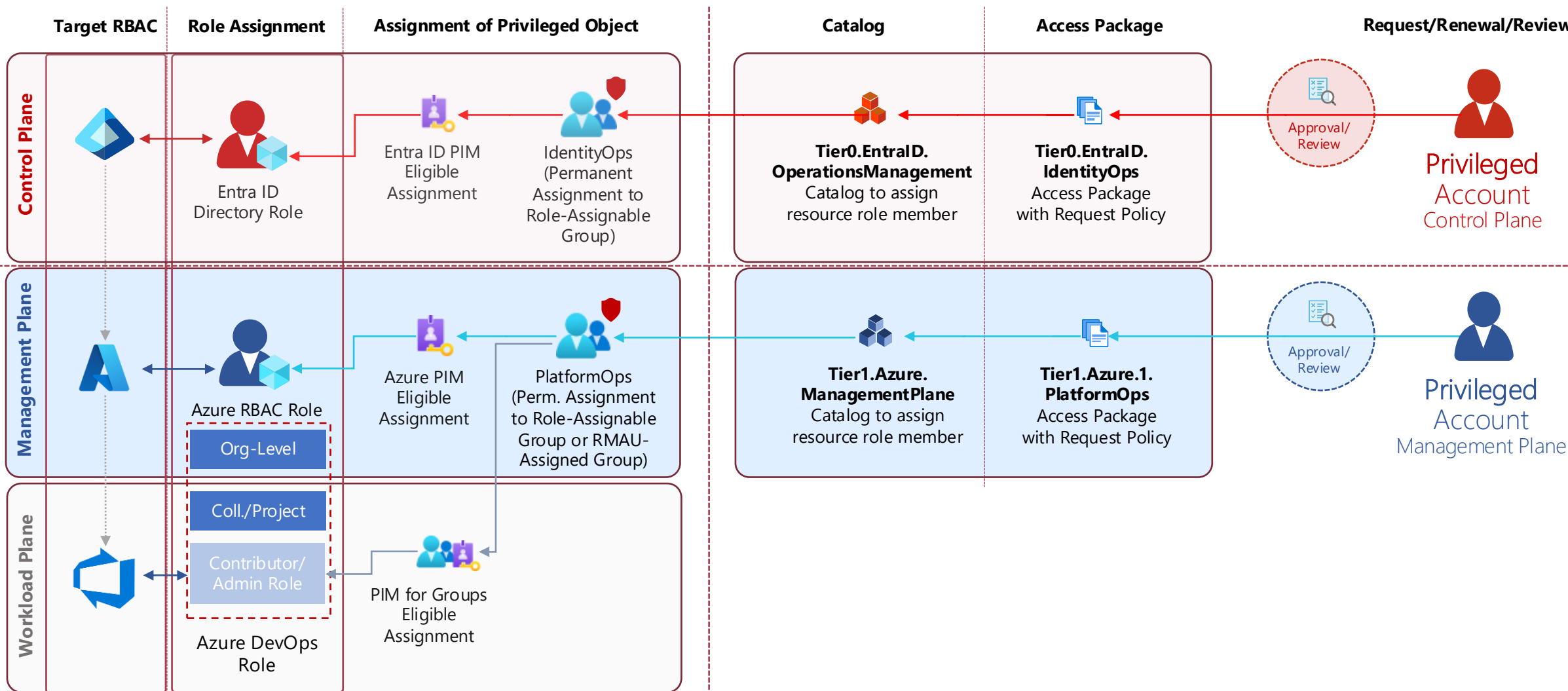
Privileged Identity Management



Entitlement Management

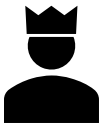


Lifecycle Workflows





Goldene Regeln für Privilegierten Zugriff



Trennung der Benutzerkonten

Stelle sicher, dass administrative (privilegierte) Konten von Standard-Benutzerkonten getrennt sind, um das Risiko einer Kompromittierung u.a. durch Internet- und E-Mail-Zugriffe zu verhindern.



Starke Sicherheitsrichtlinien

Erzwinge phishing-resistente Authentifizierung, Device Compliance- und Filter, um den Zugriff auf privilegierte Interfaces nur von autorisierten Endpoints zu gestatten



Eingeschränkte Delegation

Verwenden „Restricted Management Administrative Units“ und/oder rollen-zuweisbare Gruppen, um den Zugriff auf die privilegierten Objekte einzuschränken.



Tiered Administration

Erstellen eine klare Klassifizierung sensibler Rollen und deren Geltungsbereiche, um administrative Zugriffsbereiche zu segmentieren.



Review und Überwachung

Überprüfe regelmäßig zugewiesene, berechtigte und aktive Berechtigungen, um Anomalien, veraltete Berechtigungen oder Missbrauch zu erkennen.

PIM Alerts

Home > Browse > Identity Governance | Microsoft Entra roles > Privileged Identity Management > CloudLab | Alerts >

Alert settings

Privileged Identity Management | Microsoft Entra roles

Alert

The organization doesn't have Azure AD Premium P2

Roles don't require multi-factor authentication for activation

Eligible administrators aren't activating their privileged role

Roles are being assigned outside of Privileged Identity Management

Roles are being activated too frequently

There are too many global administrators

Potential stale accounts in a privileged role

... > Privileged Identity Management > CloudLab | Alerts >

Alert detail - Eligible administrators aren't activating their privileged role

Privileged Identity Management | Microsoft Entra roles

— Fix X Dismiss

Why am I getting this?

4 user(s) haven't activated their privileged roles in the past 30 days

[Learn more about this alert](#)

How do I fix this?

Review the users in the list and remove them from privileged roles they do not need.

Can I prevent this?

(Recommended)

Assign privileged roles to users that have a business justification. Schedule regular access reviews to verify that users still need their access.

Name	↑↓	User Principal Name	↑↓	Role Name	↑↓	Last Activation On	↑↓	Status
☐ Thomas Naunheim		thomas@cloud-architekt.net		Cloud Application Administrator				
☐ Thomas Naunheim		thomas@cloud-architekt.net		Cloud Application Administrator				
☐ Thomas Naunheim		thomas@cloud-architekt.net		Hybrid Identity Administrator		1/9/2024, 6:39:53 AM		
☐ Adele Vance		adelev_c4a8ando.net#EXT#@clou...		Attack Payload Author				
☐ admMOB1		admMOB1@lab.cloud-architekt.net		Attack Payload Author				
☐ Thomas Naunheim		thomas@cloud-architekt.net		AI Administrator				
☐ Montgomery Scott		scotty@corp.cloud-architekt.net		Cloud Application Secret Manager		12/16/2025, 7:29:05 AM		

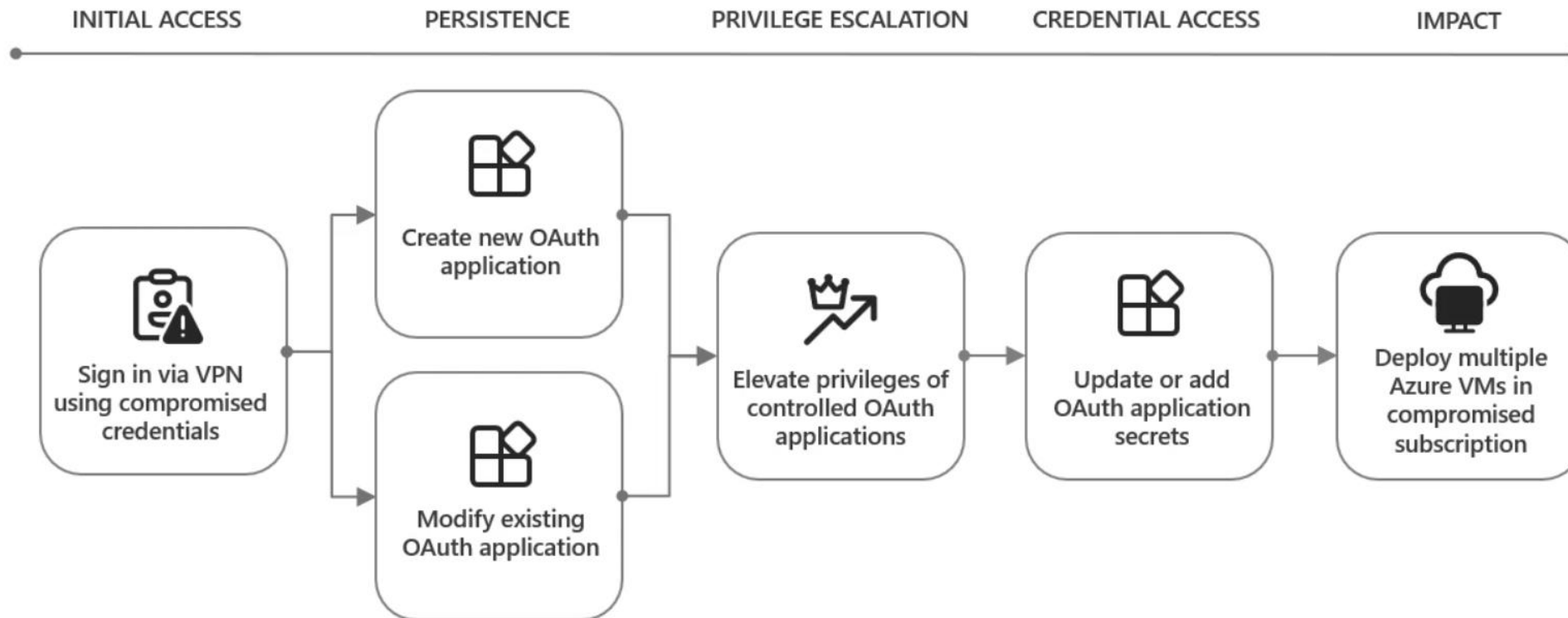


Non-Human Identities: Inventarisierung, Verwaltung und Absicherung

Attackers Service Principals



OAuth applications to deploy VMs for cryptomining



Source: [Threat actors misuse OAuth applications to automate financially driven attacks](#)



Nation-state attack by “Midnight Blizzard”

Malicious use of OAuth applications

Threat actors like Midnight Blizzard compromise user accounts to create, modify, and grant high permissions to OAuth applications that they can misuse to hide malicious activity. The misuse of OAuth also enables threat actors to maintain access to applications, even if they lose access to the initially compromised account. Midnight Blizzard leveraged their initial access to identify and compromise a **legacy test OAuth application that had elevated access to the Microsoft corporate environment.** The actor created additional malicious OAuth applications. They created a new user account to grant consent in the Microsoft corporate environment to the actor controlled malicious OAuth applications. The threat actor then used the legacy test OAuth application to grant them the Office 365 Exchange Online ***full_access_as_app* role, which allows access to mailboxes.**

Source: [Midnight Blizzard: Guidance for responders on nation-state attack](#) | Microsoft Security Blog

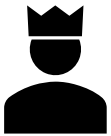


Goldene Regeln für Non-Human Identities



Sichtbarkeit

Stelle sicher, dass eine Übersicht zu allen Application-, Workload- und Agent Identities sowie deren Berechtigungen vorhanden ist.



Delegation und Least Privilege

Vermeide "Privilege Escalation" durch Nutzung von Owner-Berechtigungen auf Application- und Service Principal-Objekten. Verwende eingeschränkte Entra ID Rollen und Scopes.



App Inventory and Insights for SOC by using WorkloadIdentityInfoXDR

Advanced hunting - Microsoft

https://security.microsoft.com/v2/advanced-hunting?tid=36955ea9-c98e-4749-b603-ffefe652dd90

Microsoft Defender

Search

Help resourcesQuery resources reportSchema referencePage preferences

Advanced hunting

Selected workspace: lab-la-4d3e5b65-8a52-4b2f-b5cd-1670c700136b

New query*New query*+New query*

Run queryLast 30 daysSaveShare linkCreate summary ruleCreate detection rule

Query

1 WorkloadIdentityInfoXdr

Getting startedResultsQuery history

ExportLink to incidentTake actionsShow empty columns1 of 54 selectedSearch00:11.906LowChart typeFull screen

Filters: Add filter

	ServicePrincipalName	ServicePrincipalId	OAuthAppId	CriticalityLevel	AddedOnTime	LastModifiedTime	AppStatus	VerifiedPublisher
☒	> aadexporter-sp	ad4f7ea9-521d-422c-a3...	20f7a103-e7eb-49cf-9cf...		May 13, 2021 1:22:38 PM		Enabled	{}
☐	> aadops-pull-sp	01b83e5e-eca2-40cc-92...	8d49d8d1-c448-4996-a...		Jan 18, 2021 2:48:11 PM		Enabled	{}
☐	> ASPADev	5892a25b-509f-4f3e-acc...	1309b33f-ecf2-4786-aa1...		Jul 1, 2025 11:24:59 AM		Enabled	{}
☐	> AzADServicePrinci...	df91eeca-9fc9-49d3-aaa...	e7843299-6dab-4683-8...		Apr 9, 2022 10:56:57 PM		Enabled	{}
☐	> AzGovViz	4434a136-a704-4306-8...	34f7258a-81a0-4f72-bbf...		Jan 11, 2022 9:21:48 AM	Jun 12, 2023 11:52:48 AM	DisabledByUser	{}
☐	> azops-pull-sp	deea7af6-3531-41a0-b8...	e96c653b-9ea0-4bcf-b0...		Oct 18, 2020 9:38:28 AM		Enabled	{}
☐	> AzSentinel-Playbo...	1c334d68-ce72-4efa-a0...	5d6db40a-65a4-4fb2-a...		Sep 10, 2021 9:04:48 AM		Enabled	{}
☐	> Azure AD Terraform	86c4ff0b-b24d-431f-b5...	acc97b04-e430-4541-99...	1	Nov 21, 2022 7:40:01 AM		Enabled	{}
☐	> Azure Logic Apps ...	3037993f-35f8-46d2-be...	b2a54184-d0c5-4c6a-af...		Mar 26, 2021 12:18:05 PM		Enabled	{}

Query: Cloud-Architekt/AzureSentinel - WorkloadIdentityInfoXdr



Experts LIVE Germany

Critical default permissions

- By default, no limitation to require assignment to access Enterprise Apps

 **Graph explorer (official site) | Properties**
Enterprise Application

Assignment required? ⓘ

Yes No

Assign users and groups to app-roles for your application here. App-roles are made available by the developer of the application by using the application registration.

☐	 DU	dug_AAD.PrivilegedAccounts	Group	Default Access
--------------------------	---	----------------------------	-------	----------------

- Default permission for (Member) user on Enterprise Apps (Service Principals)

App registrations
Users can register applications ⓘ

Yes No

 **Application developer**
Description: Users in this role will continue to be able to register app registrations even if the Global Admin has turned off the tenant level switch for "Users can register apps".



Default assigned ownership by creation

Microsoft Entra admin center

Search resources, services, and docs (G+)

Copilot

scotty@corp.cloud-arch...
CLOUDLAB (CLOUD-ARCHITECT...

Home

Entra agents

Favorites

Entra ID

Overview

Users

Groups

Devices

Agent ID (Preview)

Enterprise apps

App registrations

Roles & admins

Delegated admin partners

Domain services

Conditional Access

Multifactor authentication

...

App registrations

My App | Owners

Roles and administrators | All roles

Application Developer | Description

App registrations

Roles and administrators | All roles

Montgomery Scott

Montgomery Scott

User

Search

+ Add assignments

Refresh

Got feedback?

Eligible assignments

Active assignments

Expired assignments

Search by role

Role	Principal name	Scope	Membership	State	Start time	End time	Action
Application Developer	scotty@corp.cloud-a...	Directory	Direct	Active	12/16/2025, 7:27:08 ...	12/16/2025, 10:25:04...	Remove L

Assigned roles

Administrative units

Groups

Applications

Licenses

Devices

Azure role assignments

Authentication methods

New support request

Compare member / guest default permissions

Area	Member user permissions	Default guest user permissions	Restricted guest user permissions
Applications	• Register (create) new applications • Enumerate the list of all applications • Read properties of registered and enterprise applications • Manage application properties, assignments, and credentials for owned applications • Create or delete application passwords for users • Delete owned applications • Restore owned applications • List permissions granted to applications	• Read properties of registered and enterprise applications • List permissions granted to applications	• Read properties of registered and enterprise applications • List permissions granted to applications

Who or what defines the privileges for users and guest?

Authorization Policy **and**
Entra Role Definition



Role Actions by Conditions "SubjectIsOwner"

"microsoft.directory/applications/appRoles/update",
"microsoft.directory/applications/credentials/update",
"microsoft.directory/applications/delete",
"microsoft.directory/applications/owners/update",
"microsoft.directory/applications/permissions/update",
"microsoft.directory/deletedItems.applications/delete",
"microsoft.directory/deletedItems.applications/restore",
"microsoft.directory/deletedItems.groups/restore",
"microsoft.directory/devices/disable",
"microsoft.directory/groupsAssignableToRoles/allProperties/update",
"microsoft.directory/groupsAssignableToRoles/delete",
"microsoft.directory/groupsAssignableToRoles/restore",
"microsoft.directory/groups/delete",
"microsoft.directory/groups/groupType/update",
"microsoft.directory/groups/members/update",
"microsoft.directory/groups/owners/update",
"microsoft.directory/groups/restore",
"microsoft.directory/policies/basic/update",
"microsoft.directory/policies/delete",
"microsoft.directory/policies/owners/update",
"microsoft.directory/servicePrincipals/appRoleAssignedTo/update",
"microsoft.directory/servicePrincipals/basic/update",
"microsoft.directory/servicePrincipals/credentials/update",
"microsoft.directory/servicePrincipals/delete",
"microsoft.directory/servicePrincipals/owners/update",
"microsoft.directory/servicePrincipals/permissions/update",
...

Owners vs. Object-level Entra ID role



Custom Roles for App Registration

 **Application Creator without Owner** | Description ...

Privileged Identity Management | Microsoft Entra roles

>>  Edit  Delete |  Got feedback?

Summary

Name: Application Creator without Owner

Description: Users in this role will be able to register app registrations without becoming owner.

Template ID: b6dda220-f45d-4348-8cdb-db0033cd795b

Role permissions

microsoft.directory/applications/create	Create all types of applications
microsoft.directory/servicePrincipals/create	Create service principals

Custom Roles for App Registration

[Home](#) > [All roles](#) >

New custom role

All roles

 Got feedback?

☐	microsoft.directory/applications.myOrganization/allProperties/read	Read all properties (including privileged properties) on single-directory applica...	
☐	microsoft.directory/applications.myOrganization/allProperties/update	Update all properties (including privileged properties) on single-directory appli...	PRIVILEGED
☐	microsoft.directory/applications.myOrganization/audience/update	Update audience on single-directory applications	
☐	microsoft.directory/applications.myOrganization/authentication/update	Update authentication on single-directory applications	
☐	microsoft.directory/applications.myOrganization/basic/update	Update basic properties on single-directory applications	
☐	microsoft.directory/applications.myOrganization/credentials/update	Update credentials on single-directory applications	PRIVILEGED
☐	microsoft.directory/applications.myOrganization/delete	Delete single-directory applications	
☐	microsoft.directory/applications.myOrganization/owners/read	Read owners on single-directory applications	
☐	microsoft.directory/applications.myOrganization/owners/update	Update owners on single-directory applications	
☐	microsoft.directory/applications.myOrganization/permissions/update	Update exposed permissions and required permissions on single-tenant applic...	
☐	microsoft.directory/applications.myOrganization/standard/read	Read basic properties on single-directory applications	
☐	microsoft.directory/applications/allProperties/read	Read all properties (including privileged properties) on all types of applications	
☐	microsoft.directory/applications/allProperties/update	Update all properties (including privileged properties) on all types of applicatio...	PRIVILEGED
☐	microsoft.directory/applications/applicationProxy/read	Read all application proxy properties	
☐	microsoft.directory/applications/applicationProxy/update	Update all application proxy properties	
☐	microsoft.directory/applications/applicationProxyAuthentication/update	Update authentication on all types of applications	

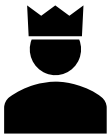


Goldene Regeln für Non-Human Identities



Sichtbarkeit

Stelle sicher, dass eine Übersicht zu allen Application-, Workload- und Agent Identities sowie deren Berechtigungen vorhanden ist.



Delegation und Least Privilege

Vermeide "Privilege Escalation" durch Nutzung von Owner-Berechtigungen auf Application- und Service Principal-Objekten. Verwende eingeschränkte Entra ID Rollen und Scopes.



Eingeschränkte Delegierung

Erlaube nur sichere Credential Types und Issuer durch definierte Policies in Microsoft Azure und Entra ID und schränke die Nutzung von (langlebigen) Client Secrets ein.



Lebenszyklus

Überwache die Nutzung von Non-Human Identities sowie deren zugewiesene Berechtigungen und Verwendung. Etabliere einen standardisierten On- und Offboarding sowie Access Governance für diese.



Hands-on Workload Identities:

4.1 Überprüfen von Recommendations
im Microsoft Entra Portal

4.2 Benutzerdefinierte Rolle auf
Objektebene für delegierte
Application-Management

4.3 Default Application Policies
überprüfen

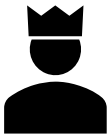


Goldene Regeln für Non-Human Identities



Sichtbarkeit

Stelle sicher, dass eine Übersicht zu allen Application-, Workload- und Agent Identities sowie deren Berechtigungen vorhanden ist.



Delegation und Least Privilege

Vermeide "Privilege Escalation" durch Nutzung von Owner-Berechtigungen auf Application- und Service Principal-Objekten. Verwende eingeschränkte Entra ID Rollen und Scopes.



Eingeschränkte Delegierung

Erlaube nur sichere Credential Types und Issuer durch definierte Policies in Microsoft Azure und Entra ID und schränke die Nutzung von (langlebigen) Client Secrets ein.



Lebenszyklus

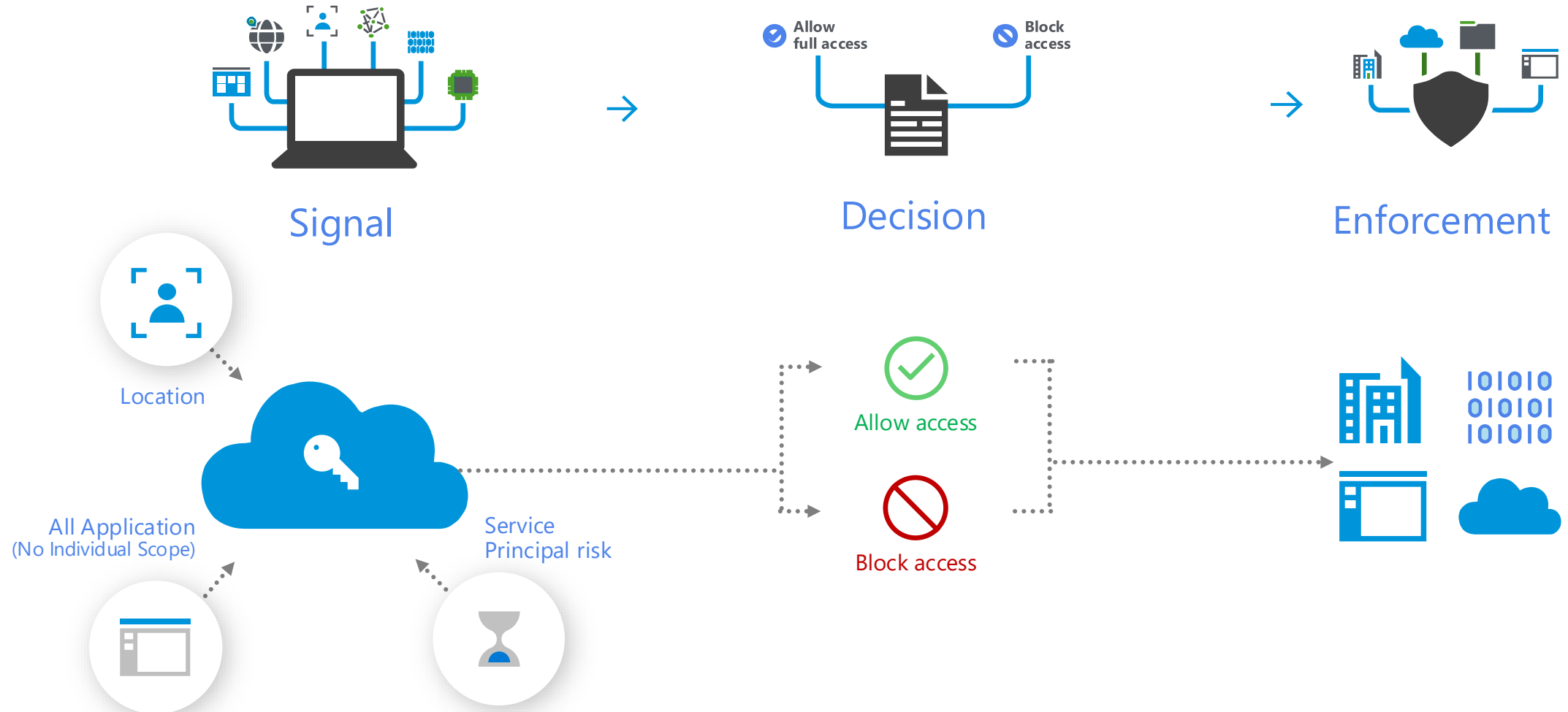
Überwache die Nutzung von Non-Human Identities sowie deren zugewiesene Berechtigungen und Verwendung. Etabliere einen standardisierten On- und Offboarding sowie Access Governance für diese.



Insights

Erkenne ungewöhnliche Aktivitäten oder Zugriffe durch Apps oder delegierte Berechtigungen auf sensible Daten oder APIs. Implementiere Policies um solche Zugriffe zu blockieren.

Workload ID Conditional Access



Conditional Access for Workload Identities

The screenshot displays the Microsoft Entra admin center interface. The left sidebar contains navigation links for Overview, Users, Groups, Devices, Agent ID (Preview), Enterprise apps, App registrations, Roles & admins, Delegated admin partners, Domain services, Conditional Access, Multifactor authentication, Identity Secure Score, Authentication methods, Account recovery (Preview), Password reset, Custom security attributes, and Certificate authorities. The main content area is titled 'Conditional Access | Policies' and shows a summary of policies created by the Conditional Access Optimization Agent (2), Microsoft-managed policies (0), and User created policies (69). A search filter for 'Workloads' is applied, resulting in 2 out of 71 policies found. The table below lists the filtered policies.

Policy name	Created by
401 - ALL - Workloads - Self Hosted Agent Pipelines: Block access from untrusted network locations	USER
402 - ALL - Workloads - High-privileged Workload Identity: Block access For When high workload identity risk is detected	USER



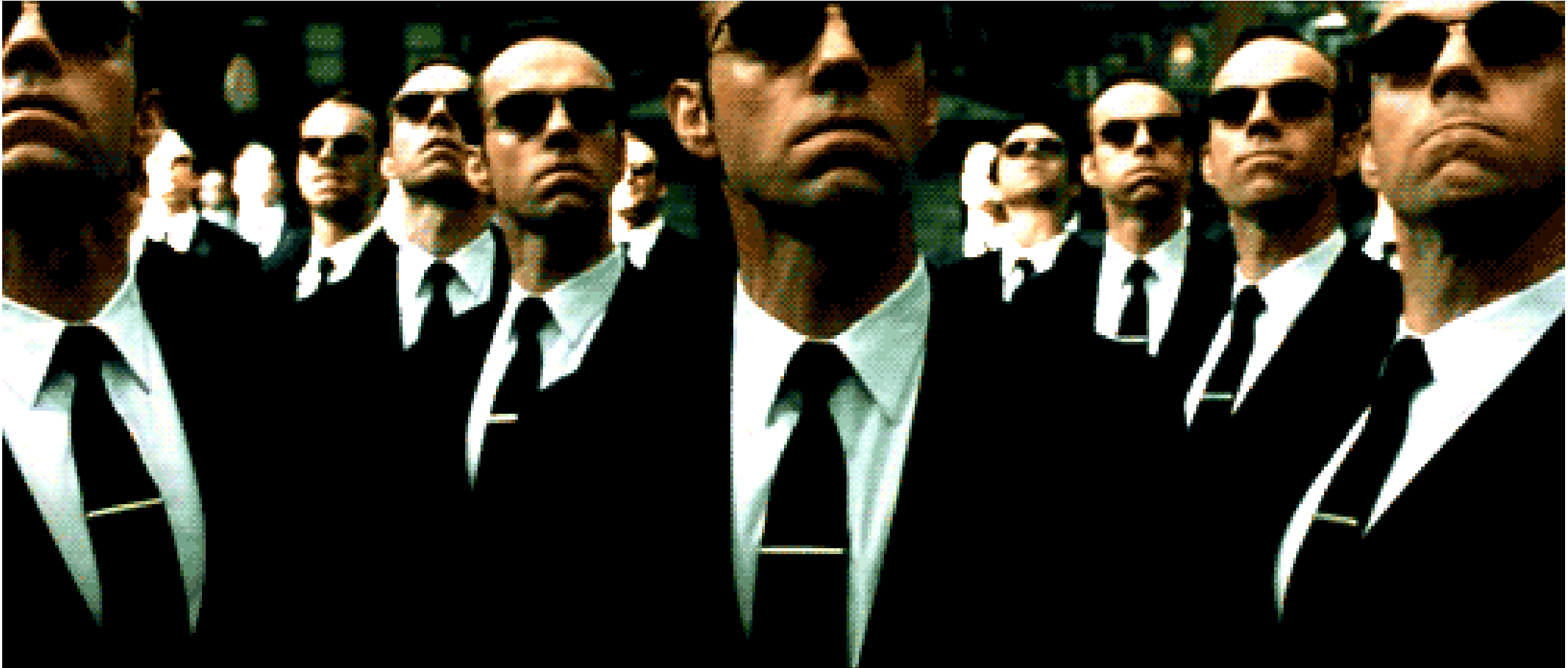
Workload Identities Premium?

Feature	Free (Azure AD License)	Premium (\$3/Month/Service Principal)
Authentication, Authorization, Sign-in and Audit Logs	Yes	Yes
Conditional Access	No	Yes
Access Reviews	No	Yes
Identity Protection	No	Yes
App Management Policies	Yes	Yes
App Health Recommendations	Yes	Yes
MDA App Governance	Add-on to MDA, free for E5 customers (since June 1 st , 2023)	

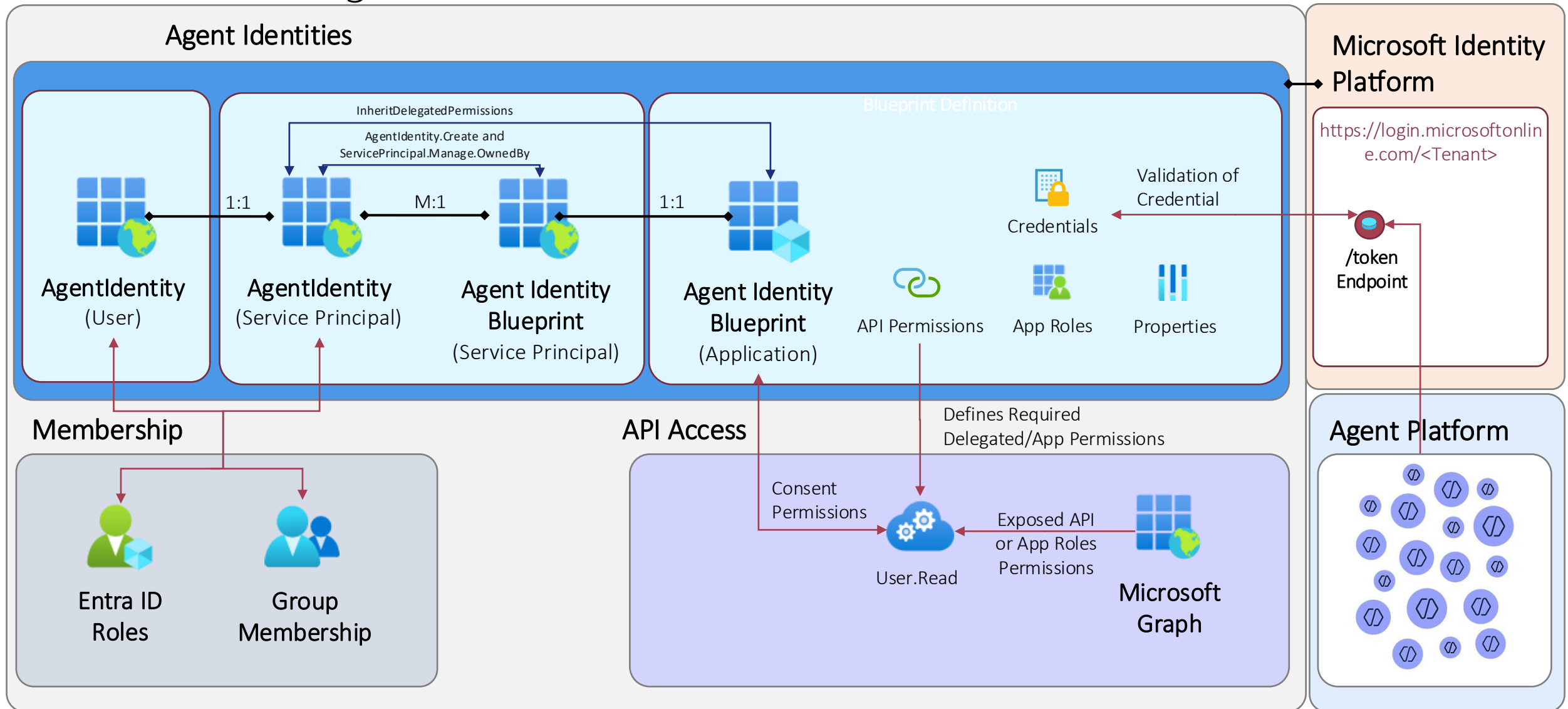
Experts LIVE Germany

Experts LIVE Germany

What about Agents?



Overview of Agent Identities



Portals and Inventories for Agents





Hands-on Workload Identities:

4.5 Überprüfung von Agenten-
Identitäten



Vielen Dank an unsere Sponsoren!

Diamond



Platinum



Gold





Bitte gebt uns euer Feedback!

Feedback geben und Geschenk mitnehmen

Vielen Dank!